REPUBLIQUE DU CAMEROUN
Paix - Travail - Patrie

UNIVERSITE DE DOUALA

ECOLE DOCTORALE DES SCIENCES FONDAMENTALES ET APPLIQUEES

Unité de Formation Doctorale des Sciences de l'Ingénieur

Laboratoire de Génie Informatique Sciences de Données et Intelligence Artificielle (LGISDIA)

REPUBLIC OF CAMEROON
Peace - Work - Fatherland

THE UNIVERSITY OF DOUALA

POSTGRADUATE SCHOOL FOR PURE AND APPLIED SCIENCES

Postgraduate Training Unit for Engineering Sciences

Laboratory of Computer Engineering, Data Science and Artificial Intelligence (LGISDIA)

COURS DE CYBERSÉCURITÉ

Master en Sciences de l'Ingénieur

Jean NDOUMBE

AVANT-PROPOS

La cybersécurité est devenue en moins de deux décennies l'un des enjeux stratégiques majeurs du XXIe siècle. Jadis réservée à un cercle restreint de spécialistes, elle irrigue désormais l'ensemble des fonctions organisationnelles — de la direction générale aux ressources humaines, en passant par les finances, les opérations et le juridique. Chaque organisation, quelle que soit sa taille ou son secteur, est aujourd'hui une cible potentielle.

Le panorama des menaces a connu une transformation radicale. Les cyberattaques ne sont plus le seul fait de pirates solitaires animés par la curiosité technique : elles constituent aujourd'hui l'instrument privilégié d'États cherchant à projeter leur puissance (APT étatiques), de groupes criminels organisés générant des milliards de dollars de revenus illicites (ransomware-as-a-service), d'hacktivistes voulant peser sur le débat public, et d'initiés malveillants. La surface d'attaque, elle, n'a cessé de s'élargir : mobilité généralisée, cloud multi-hybride, Internet des Objets (IoT), systèmes industriels connectés (OT/ICS), intelligence artificielle générative — chaque innovation technologique ouvre de nouvelles opportunités pour les attaquants.

Face à cette réalité, les organisations investissent massivement dans leur sécurité : le marché mondial de la cybersécurité dépassera 300 milliards de dollars d'ici 2027 (Gartner, 2024). Pourtant, le nombre et la gravité des incidents ne diminuent pas. Cette apparente contradiction s'explique par un facteur humain structurel : les technologies de sécurité ne peuvent être efficaces que si elles sont conçues, déployées et opérées par des professionnels compétents, et utilisées par des utilisateurs sensibilisés.

C'est l'ambition de ce cours : former des ingénieurs capables de comprendre les menaces dans leur complexité, de concevoir des architectures sécurisées, d'appliquer les cadres normatifs internationaux, et de développer le réflexe de sécurité dans chacune de leurs décisions techniques et organisationnelles. Le cours couvre les six domaines fondamentaux de la cybersécurité : les fondamentaux conceptuels, le panorama des menaces, la cryptographie et l'authentification, la sécurité des réseaux et des infrastructures, la sécurité applicative et le DevSecOps, et enfin la gouvernance, le risque, la conformité et les tendances émergentes.

Les références bibliographiques rassemblées à la fin de ce document constituent une bibliothèque de départ indispensable. La cybersécurité étant un domaine en évolution permanente, la veille continue — via les bulletins de l'ANSSI, les CVE publiés, les rapports des grands éditeurs de sécurité et les publications académiques — est une exigence professionnelle non négociable.

Structure du Cours

Chapitres 1 & 2 : Fondamentaux conceptuels — définitions, enjeux, triade CIA, défense en profondeur.

Chapitre 3 : Le cyberespace — architecture, couches, convergences technologiques, SI, IoT, données, géopolitique.

Chapitre 4 : L'espace des risques — modélisation, typologies, menaces, vulnérabilités, caractérisation, gestion des risques.

Chapitres 5 & 6 : Sécurité des réseaux et des infrastructures Sécurité applicative / DevSecOps & Gouvernance / Conformité.

Chapitre 7 : Gouvernance, risque et conformité

Chapitre 8 : Tendances émergentes (IA, IoT/OT, post-quantique, cloud, souveraineté numérique).

CHAPITRE 1 — FONDAMENTAUX DE LA CYBERSÉCURITÉ

INTRODUCTION

La cybersécurité est une discipline qui protège les systèmes numériques, les réseaux et les données contre les attaques, les dommages et les accès non autorisés. Comprendre ses fondements — définitions précises, enjeux réels, modèles conceptuels — est le prérequis absolu avant d'étudier n'importe quelle technique ou technologie de sécurité.

Ce premier chapitre pose les bases intellectuelles sur lesquelles repose l'ensemble du cours. Il répond à trois questions fondamentales : Qu'est-ce que la cybersécurité et comment la définir rigoureusement ? Pourquoi est-elle devenue un enjeu stratégique de premier ordre ? Sur quels modèles conceptuels construire une démarche de sécurité solide ?

OBJECTIFS PÉDAGOGIQUES

- ✓ Maîtriser les définitions rigoureuses de la cybersécurité selon les référentiels institutionnels (ANSSI, NIST, ISO, UIT)
- ✓ Comprendre et analyser les enjeux économiques, géopolitiques, réglementaires et humains
- ✓ Appliquer la triade CIA (et ses extensions) à l'analyse de tout système d'information
- ✓ Comprendre et mettre en œuvre le principe de défense en profondeur
- ✓ Intégrer la gestion des risques comme paradigme central de toute démarche de sécurité
- ✓ Distinguer les différents types de contrôles de sécurité et leurs usages

1.0 Définitions et périmètre de la cybersécurité

Avant d'étudier les mécanismes, il est essentiel de définir précisément de quoi l'on parle. La cybersécurité souffre d'une profusion de termes employés parfois de façon interchangeable — cybersécurité, sécurité informatique, sécurité de l'information, sécurité des systèmes d'information — alors qu'ils recouvrent des périmètres distincts.

1.0.1 Définitions institutionnelles de référence

Source	Description
ANSSI (France)	La cybersécurité est l'état recherché pour un système d'information lui permettant de résister à des événements issus du cyberespace susceptibles de compromettre la disponibilité, l'intégrité ou la confidentialité des données stockées, traitées ou transmises et des services connexes.
NIST (USA)	La prévention des dommages, la protection et la restauration des ordinateurs, des systèmes de communication électronique, des communications filaires et électroniques, y compris les informations contenues, afin d'en assurer la disponibilité, l'intégrité, l'authentification, la confidentialité et la non-répudiation.
ISO/IEC 27032	La préservation de la confidentialité, de l'intégrité et de la disponibilité de l'information dans le cyberespace. Le cyberespace désigne l'environnement complexe résultant de l'interaction de personnes, de logiciels et de services sur Internet.
Directive NIS2 (UE 2022)	Les mesures visant à protéger les réseaux et les systèmes d'information, les utilisateurs de ces systèmes et les autres personnes concernées contre les incidents pouvant affecter la disponibilité, l'authenticité, l'intégrité et la confidentialité des données.
Lallement (2024)	La cybersécurité englobe 3 domaines non-disjoints : la sécurité des systèmes d'information (SSI), la lutte contre la cybercriminalité, et la cyberdéfense.

1.0.2 Distinctions terminologiques essentielles

Historiquement, la sécurité informatique s'est d'abord focalisée sur la protection physique des équipements (années 1960-1970), puis sur la sécurité logicielle et les premières politiques de contrôle d'accès (années 1980). L'avènement d'Internet dans les années 1990 a fondamentalement modifié le paradigme : la connectivité généralisée a multiplié exponentiellement les surfaces d'attaque et rendu obsolètes les modèles de sécurité périmétrique traditionnels. Les années 2000-2010 ont vu l'industrialisation de la cybercriminalité et l'émergence des premières cyberarmes étatiques (Stuxnet, 2010). La décennie 2010-2020 a été marquée par la prolifération des ransomwares, des violations de données massives (Equifax, Yahoo, Facebook) et des attaques sur les chaînes d'approvisionnement. Depuis 2020, l'accélération de la transformation numérique post-COVID et l'émergence de l'IA générative ont ouvert de nouveaux fronts.

1.0.2 Distinction entre sécurité informatique, sécurité de l'information et cybersécurité

Ces trois termes, souvent utilisés de manière interchangeable, recouvrent des réalités distinctes qu'il convient de clarifier :

La sécurité informatique (IT security) désigne la protection des systèmes informatiques — hardware, software, réseaux — contre les menaces techniques. Son périmètre est essentiellement technique.

La sécurité de l'information (information security, souvent abrégée InfoSec) adopte une vision plus large englobant toutes les formes d'information, qu'elles soient numériques ou non (documents papier, conversations orales, etc.). Elle intègre les dimensions humaines, organisationnelles et physiques en sus des aspects techniques. Le référentiel ISO/IEC 27001 adopte cette approche systémique.

La cybersécurité constitue une spécialisation focalisée sur les menaces opérant dans et via le cyberespace — c'est-à-dire l'espace numérique interconnecté formé par l'ensemble des réseaux de communication, systèmes d'information et données numériques. Elle englobe à la fois des dimensions techniques, humaines, juridiques, géopolitiques et éthiques.

COMPARATIF DES TROIS CONCEPTS	
Sécurité informatique	Portée technique — protection des équipements et logiciels
Sécurité de l'information	Portée étendue — information sous toutes formes (ISO 27001)
Cybersécurité	Portée cyber — menaces du cyberespace, dimension géopolitique

Notion	Description
Sécurité de l'information (IS)	Périmètre le plus large. Protège l'information sous toutes ses formes (numérique, papier, orale). Standard ISO 27001.
Sécurité des SI (SSI)	Concentrée sur les systèmes d'information — matériel, logiciel, réseaux, données numériques. Terme historique français.
Cybersécurité	Met l'accent sur la dimension cyber — les systèmes interconnectés, Internet, le cyberespace. Terme dominant aujourd'hui.
Cyberdéfense	SSI appliquée aux organismes d'importance vitale. Implique des exigences de résilience et de continuité. Dimension étatique et militaire.
Cybercriminalité	Ensemble des infractions pénales commises via les systèmes numériques. Inclut les fraudes, les atteintes aux systèmes, le vol de données.
Résilience cyber	Capacité à anticiper, résister, s'adapter et se remettre d'un incident cyber tout en maintenant les fonctions critiques.

1.1 Les enjeux de la cybersécurité

La cybersécurité n'est plus un sujet purement technique. Elle est devenue un enjeu stratégique multidimensionnel qui touche simultanément l'économie mondiale, la géopolitique, le droit, la société et le facteur humain.

1.1.1 Enjeux économiques

Le coût global de la cybercriminalité dépasse désormais le PIB de la majorité des nations. Cybersecurity Ventures estimait ce coût à 8 000 milliards de dollars en 2023, avec une projection à 10 500 milliards de dollars en 2025. Le rapport IBM Cost of a Data Breach 2024 révèle un coût moyen par violation de 4,88 millions de dollars — en hausse de 10 % par rapport à 2023. Le secteur de la santé affiche le coût moyen le plus élevé : 9,77 millions de dollars par incident.

L'impact économique dépasse les coûts directs pour inclure des coûts indirects sous-estimés : perte de revenus pendant l'interruption (downtime), coûts de recrutement post-incident, perte de clients (34 % quittent l'organisation après une violation selon PwC), atteinte à la valorisation boursière (−3 à −7 % en moyenne dans les jours suivant l'annonce), et hausse des primes d'assurance cyber.

1.1.2 Enjeux géopolitiques

Le cyberespace est devenu le 5ème domaine de conflictualité, aux côtés du terrestre, maritime, aérien et spatial. Stuxnet (2010), attribué aux États-Unis et Israël, est le premier cyberarmement ayant causé des dommages physiques réels (destruction de centrifugeuses iraniennes). NotPetya (2017), attribué à la Russie, a causé plus de 10 milliards de dollars de dommages à des entreprises mondiales. La France s'est dotée du COMCYBER (2017) et d'une doctrine de cyberdéfense explicite incluant des capacités offensives.

1.1.3 Enjeux réglementaires

Réglementation	Description
RGPD (2018)	Protection des données personnelles. Sanctions jusqu'à 4 % du CA mondial. Notification des violations en 72h.
NIS2 (2024)	~10 000 entités en France. Obligations de gestion des risques, notification d'incidents, responsabilisation des dirigeants.
DORA (2025)	Résilience opérationnelle du secteur financier. Tests de pénétration obligatoires (TLPT). Gestion des prestataires tiers TIC.
EU Cyber Resilience Act	Sécurité des produits numériques. Les fabricants sont responsables de la sécurité by design pendant tout le cycle de vie.
EU AI Act (2024)	IA dans les infrastructures critiques classée haut risque. Exigences de transparence, robustesse, supervision humaine.

1.2 La Triade CIA — Piliers fondamentaux

Le modèle CIA (Confidentiality, Integrity, Availability) constitue le fondement conceptuel universel de toute démarche de sécurité. Formulé dès les années 1970 dans le contexte de la sécurité des

systèmes d'information gouvernementaux américains, il reste aujourd'hui la référence universelle pour évaluer et concevoir des dispositifs de sécurité. Sa force réside dans sa simplicité : trois propriétés fondamentales, universellement applicables, quel que soit le contexte. Ces propriétés constituent les critères DICP (Disponibilité, Intégrité, Confidentialité, Preuve) — le « P » de Preuve (traçabilité, authentification, imputabilité) complétant utilement la triade CIA.

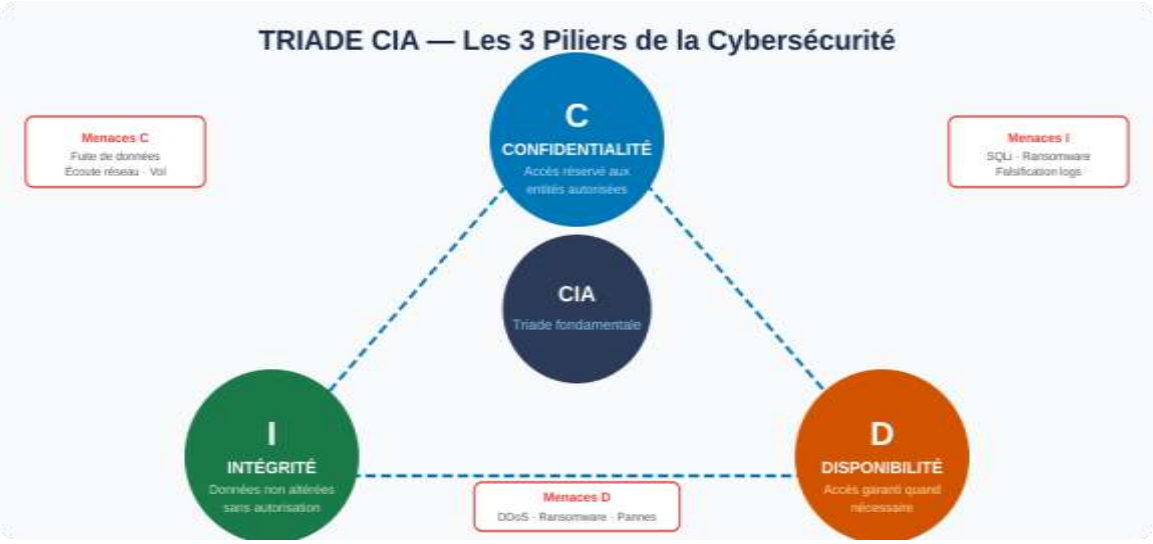

Figure 1 — La Triade CIA / Critères DICP : piliers fondamentaux de la cybersécurité

1.2.1 Confidentialité

La confidentialité garantit que les informations ne sont accessibles qu'aux entités (personnes, processus, systèmes) dûment autorisées à y accéder. Cette propriété est menacée par toute forme d'accès non autorisé : interception de communications (écoutes, man-in-the-middle), accès illicite à des bases de données, exfiltration de données par malware, ou divulgation accidentelle par des employés.

Les mécanismes techniques concourant à la confidentialité incluent le chiffrement des données au repos (AES-256) et en transit (TLS 1.3), la gestion des identités et des accès (IAM), les contrôles d'accès basés sur les rôles (RBAC) et les attributs (ABAC), et la classification des données (public, interne, confidentiel, secret).

La confidentialité est au cœur de la réglementation sur la protection des données personnelles, notamment le Règlement Général sur la Protection des Données (RGPD) en Europe, qui impose des obligations strictes de protection des données à caractère personnel sous peine de sanctions pouvant atteindre 4% du chiffre d'affaires mondial annuel.

1.2.2 Intégrité

L'intégrité garantit que les informations et les systèmes ne sont modifiés que par des processus et des personnes autorisés, et que toute modification non autorisée est détectable. Elle couvre deux dimensions : l'intégrité des données (les données ne sont pas altérées sans autorisation) et l'intégrité des systèmes (les systèmes fonctionnent conformément à leur conception, sans modification non autorisée).

Les attaques contre l'intégrité incluent les injections SQL (modification de bases de données), la falsification de fichiers de logs (pour dissimuler une intrusion), les attaques de type man-in-the-middle modifiant les communications en transit, et les ransomwares qui chiffrent les données (les rendant inutilisables sans la clé de déchiffrement).

Les mécanismes techniques d'assurance de l'intégrité comprennent les fonctions de hachage cryptographiques (SHA-256, SHA-3), les signatures numériques, les codes d'authentification de messages (HMAC), les mécanismes de contrôle d'intégrité des fichiers (tripwire, AIDE), et les journaux d'audit infalsifiables.

1.2.3 Disponibilité

La disponibilité garantit que les systèmes d'information et les données sont accessibles aux utilisateurs autorisés lorsqu'ils en ont besoin. C'est souvent la propriété la plus directement perceptible par les utilisateurs, et sa violation (panne, attaque DDoS) a un impact métier immédiat et mesurable.

Les menaces contre la disponibilité incluent les attaques par déni de service distribué (DDoS), les pannes matérielles et logicielles, les ransomwares (qui rendent les données inaccessibles par chiffrement), les catastrophes naturelles, et les erreurs humaines. Les attaques DDoS ont atteint des volumes records en 2023-2024, certaines dépassant 1 Tbps grâce aux botnets IoT.

Les mesures de protection de la disponibilité couvrent la redondance et la haute disponibilité (clusters, load balancing), les sauvegardes testées et externalisées (règle 3-2-1 : 3 copies, 2 supports différents, 1 hors site), les plans de continuité d'activité (PCA), les plans de reprise d'activité (PRA), et les capacités anti-DDoS.

EXTENSION DU MODÈLE CIA : LA TRIADE CIA+
Authentification (Authentication) : Vérification de l'identité déclarée — condition préalable à tout contrôle d'accès.
Non-répudiation : Impossibilité pour un émetteur de nier avoir envoyé un message ou effectué une action (signatures numériques).
Traçabilité (Accountability) : Capacité à identifier de manière certaine l'auteur de chaque action sur un système.
Ces propriétés étendent le modèle CIA original vers ce que l'on appelle parfois le modèle Parkerian Hexad (Donn Parker, 1998).

1.3 Concepts fondamentaux : vocabulaire de la cybersécurité

1.3.1 Le triangle Vulnérabilité – Menace – Risque

La compréhension précise de la distinction entre ces trois concepts est indispensable à toute démarche de sécurité rigoureuse :

Une **vulnérabilité** est une faiblesse intrinsèque d'un système, d'un logiciel, d'un processus ou d'une organisation, susceptible d'être exploitée par une menace pour causer un préjudice. Les vulnérabilités peuvent être d'origine technique (bug de code, mauvaise configuration), humaine (manque de sensibilisation, négligence) ou organisationnelle (absence de procédures). Elles sont répertoriées dans la base CVE (Common Vulnerabilities and Exposures) gérée par MITRE, qui en a enregistré plus de 240 000 depuis sa création en 1999.

Une **menace** est un événement, un acteur ou un scénario susceptible d'exploiter une ou plusieurs vulnérabilités pour causer un préjudice à un système ou une organisation. Les menaces peuvent être intentionnelles (cyberattaquants, espions industriels) ou accidentelles (erreurs humaines, pannes matérielles, catastrophes naturelles). La taxonomie des menaces distingue généralement les menaces internes (insiders) des menaces externes, et les menaces délibérées des menaces accidentelles.

Un **risque** est la combinaison de la probabilité qu'une menace exploite une vulnérabilité et de l'impact potentiel de cette exploitation sur l'organisation. Il se formalise par la relation : Risque = f(Probabilité, Impact). La gestion des risques (risk management) vise à réduire le risque à un niveau acceptable — le risque résiduel — en appliquant des mesures de sécurité appropriées. On distingue quatre stratégies de traitement du risque : l'acceptation, la réduction (mitigation), le transfert (assurance cyber) et l'évitement.

1.3.2 Actifs et surfaces d'attaque

Un actif (asset) est tout élément ayant de la valeur pour l'organisation et méritant d'être protégé. En cybersécurité, les actifs incluent les données (données clients, propriété intellectuelle, données financières), les systèmes et applications, les infrastructures réseau, les équipements matériels, et les ressources humaines. La démarche d'analyse des risques débute systématiquement par l'inventaire et la valorisation des actifs.

La surface d'attaque désigne l'ensemble des points d'entrée potentiels qu'un attaquant pourrait exploiter pour accéder à un système. Elle se décompose en surface d'attaque numérique (interfaces réseau, API exposées, services web, ports ouverts), surface d'attaque physique (accès physique aux équipements, ports USB, médias amovibles) et surface d'attaque sociale (personnes susceptibles d'être manipulées par ingénierie sociale). La réduction de la surface d'attaque — principe de minimalisation — est l'une des bonnes pratiques fondamentales : ne déployer que les services strictement nécessaires, désactiver les fonctionnalités inutiles, fermer les ports non utilisés.

1.4 Défense en profondeur et gestion des risques

Emprunté au domaine militaire (defense in depth), ce principe de sécurité préconise la mise en place de multiples couches de contrôles de sécurité indépendants, de sorte que la compromission d'une couche n'entraîne pas automatiquement la compromission de l'ensemble du système. L'idée fondamentale est qu'aucune mesure de sécurité n'est infaillible : il faut donc superposer les obstacles pour augmenter le coût et la complexité d'une attaque.

Une architecture de défense en profondeur type comprend : la sécurité physique (contrôle d'accès aux datacenters), la sécurité du périmètre réseau (firewalls, IDS/IPS), la segmentation réseau (VLAN, DMZ), la sécurité des endpoints (antivirus, EDR), la sécurité applicative (WAF, validation des entrées), la sécurité des données (chiffrement, DLP), la gestion des identités et des accès (IAM, MFA), et la surveillance et détection (SIEM, SOC).

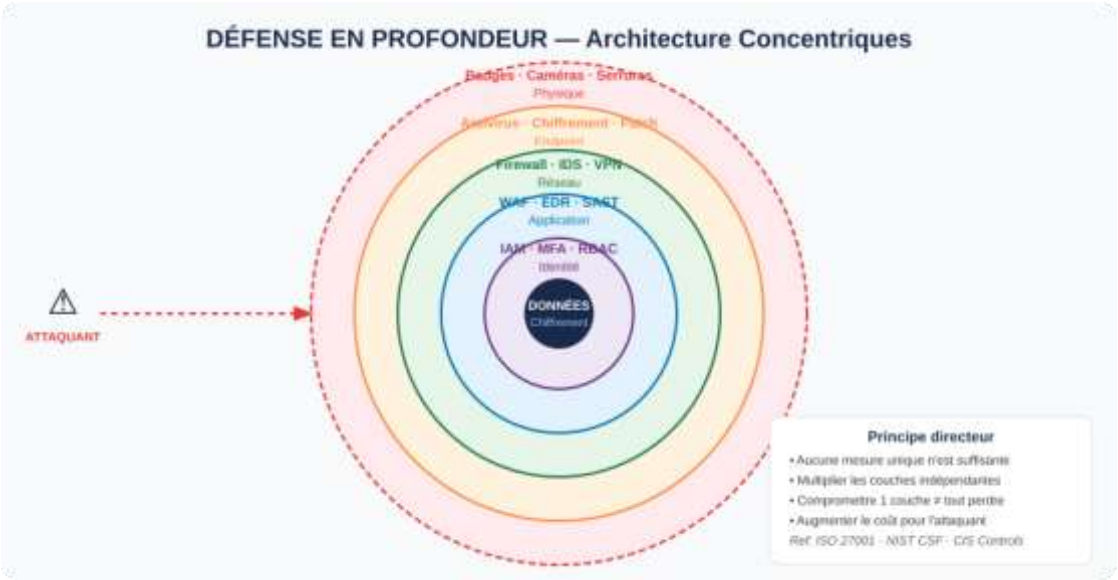

Figure 2 — Architecture de Défense en Profondeur — Modèle concentrique

La défense en profondeur superpose plusieurs couches de contrôles indépendants. La compromission d'une couche ne doit pas entraîner celle de l'ensemble. De la protection physique jusqu'à la protection des données, chaque couche impose à l'attaquant de développer de nouvelles techniques. Le moindre privilège — chaque entité dispose uniquement des droits nécessaires à sa fonction — est le principe transversal à toutes les couches.

La gestion des risques est le paradigme central : Risk = Likelihood × Impact. Elle suit un cycle en 4 phases — Identification, Estimation (qualification p et G), Évaluation (hiérarchisation, seuil

d'acceptabilité), Traitement (réduction, transfert, acceptation, évitement). Ce cycle est détaillé dans le Chapitre 4.

PRINCIPE DE MOINDRE PRIVILÈGE (Least Privilege)	
Définition	Chaque entité (utilisateur, processus, service) ne dispose que des droits strictement nécessaires à l'accomplissement de sa fonction légitime.
Objectif	Limiter l'impact d'une compromission : un compte compromis avec des droits limités causera moins de dégâts qu'un compte administrateur.
Application	Comptes de service dédiés, séparation des droits d'administration, revue périodique des droits (access review), gestion des comptes à privilèges (PAM).
Référence	NIST SP 800-53 AC-6, CIS Controls Control 6, ISO 27002 Annexe A 9.2.3

1.5 Acteurs de l'écosystème cyber

1.5.1 Taxonomie des attaquants

La compréhension des motivations et des capacités des différentes catégories d'attaquants est essentielle pour calibrer les défenses appropriées. On distingue généralement :

Les *script kiddies* : attaquants peu qualifiés utilisant des outils et exploits préfabriqués sans en comprendre réellement le fonctionnement. Motivés par la notoriété ou l'amusement, ils représentent un volume important d'attaques mais de faible sophistication.

Les *cybercriminels organisés* : groupes structurés opérant comme de véritables entreprises, avec des divisions spécialisées (développeurs de malwares, opérateurs de campagnes, blanchisseurs d'argent). Motivés par le gain financier, ils génèrent des revenus estimés à plus de 8 000 milliards de dollars en 2023 (Cybersecurity Ventures, 2023). Les groupes REvil, LockBit, Conti sont des exemples emblématiques.

Les *acteurs étatiques (APT)* : groupes bénéficiant du soutien, de la direction ou de la tolérance d'États-nations. Dotés de ressources considérables, ils mènent des opérations de longue durée (persistance sur plusieurs années) visant l'espionnage économique et politique, le sabotage d'infrastructures critiques, ou la guerre psychologique. Les plus documentés incluent APT28 et APT29 (Russie/SVR), APT1 et APT41 (Chine/PLA), Lazarus Group (Corée du Nord), APT34 (Iran/MOIS).

Les *hacktivistes* : attaquants motivés par des convictions politiques, idéologiques ou sociales. Anonymous, LulzSec, GhostSec en sont les représentants les plus connus. Leurs actions incluent les défacements de sites, les fuites de données et les DDoS contre des organisations qu'ils considèrent adversaires.

Les *initiés malveillants (insiders)* : employés, ex-employés, sous-traitants ou partenaires ayant un accès légitime aux systèmes et l'utilisant de manière malveillante. Particulièrement dangereux car ils contournent les défenses périmètriques et connaissent l'architecture interne. Le rapport Verizon DBIR 2024 indique que les menaces internes représentent 35% des violations de données.

1.5.2 Acteurs de la défense

Du côté défensif, l'écosystème comprend les équipes internes de sécurité (RSSI/CISO, équipes SOC, architectes sécurité, développeurs SecDevOps), les organismes institutionnels (ANSSI en France, ENISA en Europe, CISA aux États-Unis, CERT nationaux), les éditeurs de solutions de sécurité et les sociétés de services en cybersécurité (SSII spécialisées, red teams, sociétés de forensics), et la communauté de recherche académique et indépendante (chercheurs en vulnérabilités, experts en cryptographie, auteurs d'outils open source).

1.6 Les grandes familles de contrôles de sécurité

Les contrôles de sécurité se classifient selon leur nature et leur fonction :

TAXONOMIE DES CONTRÔLES DE SÉCURITÉ	
Préventifs	Empêchent les incidents de se produire — firewalls, chiffrement, contrôle d'accès, sensibilisation
Détectifs	Identifient les incidents en cours ou passés — IDS, SIEM, logs d'audit, outils de forensics
Correctifs	Limitent les dommages et restaurent les systèmes — sauvegardes, procédures de réponse aux incidents
Dissuasifs	Découragent les attaquants potentiels — clauses contractuelles, avertissements légaux, visibilité du dispositif
Compensatoires	Atténuent le risque quand un contrôle principal ne peut être appliqué — mesures alternatives temporaires
Physiques	Protection matérielle — serrures, badges, caméras, cages de Faraday, destruction sécurisée
Techniques	Contrôles automatisés par la technologie — antivirus, cryptographie, pare-feu, IPS
Administratifs	Politiques, procédures, formations — politique de sécurité, charte utilisateurs, PSSI

CHAPITRE 2 — PANORAMA DES MENACES ET TYPES D'ATTAQUES

INTRODUCTION

La menace cyber est protéiforme, en constante évolution, portée par des acteurs aux motivations et aux capacités extrêmement variées — du script kiddie aux services de renseignement étatiques, en passant par le crime organisé et les hacktivistes. Pour défendre efficacement, il est impératif de comprendre précisément qui attaque, avec quels outils, selon quelles méthodes, et dans quel but.

Ce chapitre cartographie l'écosystème des menaces contemporaines en combinant la vision stratégique (Cyber Kill Chain) et la vision tactique granulaire (MITRE ATT&CK). Il couvre ensuite les menaces techniques majeures — ransomware, ingénierie sociale, APT — et les vulnérabilités applicatives critiques. Les liens avec la modélisation complète du risque sont développés dans le Chapitre 4.

OBJECTIFS PÉDAGOGIQUES

- ✓ Modéliser l'anatomie d'une cyberattaque avec la Cyber Kill Chain et identifier les points d'interruption
- ✓ Utiliser le framework MITRE ATT&CK pour cartographier les TTPs des attaquants
- ✓ Analyser le fonctionnement et l'impact du ransomware moderne (modèle RaaS, double extorsion)
- ✓ Comprendre les mécanismes de l'ingénierie sociale et ses formes amplifiées par l'IA
- ✓ Identifier les vulnérabilités applicatives critiques selon l'OWASP Top 10 2021
- ✓ Distinguer les différentes catégories d'acteurs malveillants (APT, cybercriminels, insiders)

2.1 Classification des menaces cyber

La taxonomie des cybermenaces est un exercice en perpétuelle évolution, tant les techniques des attaquants se renouvellent rapidement. Nous adoptons ici une classification en quatre grandes familles : les menaces techniques (logicielles et réseaux), les menaces humaines (ingénierie sociale), les menaces sur la chaîne d'approvisionnement, et les menaces émergentes.

2.2 Malwares — Logiciels malveillants

2.2.1 Virus et vers

Un virus informatique est un programme malveillant capable de se reproduire en infectant d'autres fichiers exécutables, nécessitant une action humaine pour se propager (exécution du fichier infecté). Les virus ont marqué l'histoire de la cybersécurité dès les années 1980 (Brain, 1986 — premier virus PC connu). Leur prévalence a diminué avec l'avènement des mesures de protection modernes, mais ils restent un vecteur actif notamment via les macro-virus dans les documents Office.

Un ver informatique (worm) se distingue du virus par sa capacité à se propager de manière autonome, sans nécessiter d'intervention humaine, en exploitant des vulnérabilités réseau. WannaCry (2017), qui exploitait la vulnérabilité EternalBlue (CVE-2017-0144) affectant SMBv1 sur Windows, a infecté plus de 300 000 systèmes dans 150 pays en quelques heures, causant des dommages estimés à 4 milliards de dollars. NotPetya (2017), initialement déguisé en ransomware mais en réalité un wiper destructeur, a causé plus de 10 milliards de dollars de dommages mondiaux.

2.2.2 Trojans, backdoors et RAT

Un cheval de Troie (Trojan) est un programme malveillant dissimulé dans un logiciel apparemment légitime. Contrairement aux virus, il ne se reproduit pas ; il exécute des actions malveillantes (vol de données, installation de backdoors, téléchargement d'autres malwares) une fois activé par l'utilisateur. Les trojans bancaires (TrickBot, Emotet, QakBot) ont causé des pertes financières considérables dans le secteur bancaire.

Une backdoor est une porte dérobée permettant un accès non autorisé et persistant à un système, contournant les mécanismes d'authentification normaux. Elle peut être intentionnellement introduite par un développeur malveillant, installée par un malware, ou résulter d'une mauvaise configuration. Les Remote Access Trojans (RAT) constituent une catégorie particulièrement sophistiquée, offrant aux attaquants un contrôle complet sur le système compromis : NjRAT, AsyncRAT, Remcos sont parmi les plus répandus.

2.2.3 Ransomware — La menace dominante

Le ransomware (rançongiciel) est devenu en moins de dix ans la menace cybercriminelle la plus dévastatrice financièrement. Son principe est simple : chiffrer les données de la victime et exiger une rançon (généralement en cryptomonnaie — Bitcoin, Monero) en échange de la clé de déchiffrement. L'évolution vers le modèle Ransomware-as-a-Service (RaaS) a radicalement abaissé la barrière à l'entrée : des groupes criminels (affiliates) louent l'infrastructure d'attaque à des développeurs spécialisés, moyennant une commission de 20 à 30% des rançons obtenues.

La double extorsion (apparue en 2019 avec le groupe Maze) a aggravé le problème : les attaquants exfiltrent les données avant de les chiffrer, menaçant de les publier si la rançon n'est pas payée. La triple extorsion ajoute une pression sur les clients, partenaires et régulateurs de la victime. Le coût total des attaques ransomware a été estimé à 20 milliards de dollars en 2021 et pourrait dépasser 265 milliards de dollars d'ici 2031 (Cybersecurity Ventures, 2022).

Les groupes les plus actifs récemment incluent LockBit (neutralisé partiellement par l'opération Cronos en 2024, mais rapidement reconstitué), BlackCat/ALPHV, Clop (responsable de l'exploitation massive de MOVEit en 2023 affectant plus de 2 000 organisations), et RansomHub. L'ANSSI a

publié plusieurs avis de sécurité documentant des campagnes affectant des hôpitaux, collectivités locales et entreprises françaises (ANSSI, 2023).

2.2.4 Spyware, adware et stalkerware

Un spyware (logiciel espion) collecte des informations sur l'utilisateur à son insu : historique de navigation, frappes clavier (keylogger), captures d'écran, identifiants de connexion, communications. Pegasus (développé par NSO Group), logiciel espion gouvernemental ciblant iOS et Android, a illustré les dérives potentielles de ces technologies : son utilisation pour surveiller des journalistes, militants des droits humains et responsables politiques a provoqué un scandale international (Citizen Lab, 2021).

2.2.5 Rootkits et bootkits

Un rootkit est un ensemble d'outils permettant à un attaquant de maintenir un accès persistant et furtif à un système compromis, en dissimulant sa présence aux mécanismes de détection (antivirus, outils d'analyse système). Les rootkits de niveau noyau (kernel-level rootkits) sont particulièrement difficiles à détecter car ils opèrent avec les privilèges les plus élevés du système. Les bootkits vont plus loin encore en s'installant dans le secteur d'amorçage (MBR/VBR) ou dans le firmware UEFI, leur permettant de persister même après la réinstallation du système d'exploitation. BlackLotus (2022) est un exemple notable de bootkit UEFI contournant Secure Boot.

2.3 Attaques réseau

2.3.1 Déni de Service (DoS et DDoS)

Une attaque par déni de service (DoS — Denial of Service) vise à rendre un service indisponible en épuisant ses ressources (bande passante, CPU, mémoire, connexions). La forme distribuée (DDoS — Distributed DoS) utilise des milliers, voire des millions de machines compromises (botnets) pour amplifier l'attaque. Les botnets IoT (Mirai et ses dérivés) ont démontré dès 2016 le potentiel destructeur de l'IoT insécurisé : l'attaque contre Dyn DNS en octobre 2016 a rendu inaccessibles une grande partie d'Internet (Twitter, Netflix, Reddit, GitHub) pendant plusieurs heures.

Les vecteurs d'amplification (NTP, DNS, memcached, SSDP) permettent des facteurs de multiplication colossaux : une attaque memcached peut amplifier le trafic par un facteur 51 000, transformant 1 Gbps de trafic sortant en 51 Tbps de trafic d'attaque. Les attaques applicatives de couche 7 (HTTP floods, Slowloris, Slow POST) sont plus difficiles à distinguer du trafic légitime et nécessitent des protections spécialisées.

2.3.2 Attaques Man-in-the-Middle (MITM)

Une attaque Man-in-the-Middle place l'attaquant entre deux parties communicantes, lui permettant d'intercepter, lire, modifier et/ou injecter des communications. Les techniques incluent l'ARP poisoning (empoisonnement du cache ARP sur les réseaux locaux), le DNS spoofing (modification des réponses DNS pour rediriger le trafic), le SSL stripping (dégradation forcée d'une connexion HTTPS en HTTP), et la création de faux points d'accès Wi-Fi (evil twin).

La généralisation du chiffrement TLS a considérablement réduit l'efficacité des MITM classiques, mais de nouvelles variantes existent : l'attaque BEAST (Browser Exploit Against SSL/TLS), POODLE, et les attaques sur les certificats (utilisation de certificats frauduleux émis par des autorités de certification compromises).

2.3.3 Injection de paquets et sniffing

Le sniffing réseau (écoute passive) consiste à capturer le trafic réseau circulant sur un segment partagé. Dans les réseaux commutés modernes, l'attaquant doit d'abord placer son interface en mode promiscuous et utiliser des techniques comme l'ARP spoofing pour forcer le trafic à transiter par sa machine. Wireshark est l'outil de référence pour la capture et l'analyse de trafic, utilisé légitimement par les administrateurs pour le diagnostic mais aussi par les attaquants.

2.3.4 Scan et reconnaissance réseau

La reconnaissance réseau est la première phase de toute cyberattaque. Les outils de scan permettent d'identifier les hôtes actifs (ping sweep), les ports ouverts et services en écoute (Nmap — Network Mapper), les versions de services et systèmes d'exploitation (fingerprinting OS), et les vulnérabilités connues (Nessus, OpenVAS). Shodan.io, le moteur de recherche des appareils connectés à Internet, indexe des millions d'équipements exposés avec leurs bannières de service, offrant aux attaquants une cartographie passive de la surface d'attaque mondiale.

2.4 Ingénierie sociale — Attaques humaines

2.4.1 Phishing et ses variantes

Le phishing (hameçonnage) est une technique d'ingénierie sociale visant à tromper les victimes pour leur soutirer des informations confidentielles (identifiants, numéros de carte bancaire) ou les amener à exécuter des actions malveillantes (installer un malware, effectuer un virement). Le rapport Verizon DBIR 2024 indique que 36% des violations de données impliquent du phishing.

Le spear-phishing est une variante hautement ciblée, personnalisée en fonction de la victime (nom, fonction, contexte professionnel) pour paraître plus crédible. Le whaling cible spécifiquement les dirigeants d'entreprise. Le vishing (voice phishing) utilise les appels téléphoniques. Le smishing exploite les SMS. La fraude au président (BEC — Business Email Compromise) représente un cas particulier de spear-phishing où l'attaquant usurpe l'identité d'un dirigeant pour ordonner des virements frauduleux : le FBI estime les pertes mondiales liées au BEC à plus de 50 milliards de dollars entre 2013 et 2023.

2.4.2 Prétexting, baiting et quid pro quo

Le prétexting consiste à créer un scénario fictif (prétexte) crédible pour manipuler la victime : se faire passer pour un technicien informatique, un auditeur, un collègue de la direction, ou un représentant d'un organisme de confiance. Le baiting utilise un appât — une clé USB abandonnée dans un parking (laced USB), une offre alléchante — pour inciter la victime à installer un malware. Le quid pro quo propose un service ou avantage fictif en échange d'informations confidentielles.

Kevin Mitnick, considéré comme l'un des hackers les plus célèbres de l'histoire, a démontré dans son ouvrage « The Art of Intrusion » (2005) que l'ingénierie sociale est souvent plus efficace que les techniques techniques sophistiquées : « La sécurité est une question de psychologie autant que de technologie ».

2.5 Attaques sur les applications Web — OWASP Top 10

L'OWASP (Open Web Application Security Project) publie périodiquement sa liste des 10 risques de sécurité les plus critiques pour les applications web. La version 2021, la plus récente, constitue la référence mondiale pour la sécurité applicative :

OWASP TOP 10 — 2021 (DÉTAIL)	
A01 — Broken Access Control	1re position depuis 2021. Contrôles d'accès défaillants permettant l'accès non autorisé à des données ou fonctionnalités (IDOR, élévation de privilèges, CORS mal configuré).
A02 — Cryptographic Failures	Mauvais usage ou absence de cryptographie (transmission en clair de données sensibles, algorithmes obsolètes MD5/SHA-1, clés faibles).

A03 — Injection	Injection de code malveillant interprété par le serveur (SQLi, LDAPi, XPath, OS command injection, SSTI — Server-Side Template Injection).
A04 — Insecure Design	Failles de conception architecturale — absence de modélisation des menaces (threat modeling), de principes de sécurité dès la conception (Security by Design).
A05 — Security Misconfiguration	Mauvaise configuration des serveurs, frameworks, bases de données (comptes par défaut actifs, permissions trop larges, messages d'erreur trop verbeux révélant l'architecture).
A06 — Vulnerable/Outdated Components	Utilisation de bibliothèques, frameworks, serveurs avec des vulnérabilités connues (Log4Shell — CVE-2021-44228 — a illustré dramatiquement ce risque).
A07 — Auth Failures	Failles dans l'authentification et la gestion des sessions (mots de passe faibles, absence de MFA, sessions non invalidées, tokens prévisibles).
A08 — Software/Data Integrity Failures	Absence de vérification de l'intégrité des mises à jour logicielles et des pipelines CI/CD (attaque SolarWinds).
A09 — Security Logging/Monitoring	Journaux insuffisants ou non surveillés retardant la détection et la réponse aux incidents.
A10 — SSRF	Server-Side Request Forgery — le serveur est amené à effectuer des requêtes vers des ressources internes non autorisées (accès aux métadonnées cloud AWS/Azure/GCP).

Figure 5 — OWASP Top 10 2021 : Les 10 risques de sécurité les plus critiques

2.5.1 Injection SQL — Analyse

L'injection SQL (SQLi) est l'une des vulnérabilités les plus anciennement documentées et pourtant toujours très répandue. Elle exploite la fusion entre les données et les instructions SQL dans des requêtes mal construites. Une requête vulnérable comme SELECT * FROM users WHERE username = [input] peut être contournée par la saisie ' OR 1=1 -- qui rend la condition WHERE toujours vraie.

Les techniques avancées incluent l'injection en aveugle (blind SQLi), où l'attaquant infère des informations en posant des questions booléennes au serveur (True/False), et l'injection temporelle (time-based blind SQLi) qui utilise des délais de réponse pour exfiltrer des données. sqlmap est l'outil automatisé de référence pour la détection et l'exploitation des injections SQL. Les contre-mesures incluent les requêtes paramétrées (prepared statements), les procédures stockées, la validation des entrées, et le principe de moindre privilège pour les comptes de base de données.

2.5.2 Cross-Site Scripting (XSS)

Le Cross-Site Scripting (XSS) permet à un attaquant d'injecter des scripts malveillants (généralement JavaScript) dans des pages web visualisées par d'autres utilisateurs. Le XSS réfléchi (reflected XSS) est inclus dans l'URL et exécuté immédiatement ; le XSS stocké (stored/persistent XSS) est enregistré dans la base de données du serveur et exécuté pour chaque visiteur de la page concernée ; le XSS basé sur le DOM (DOM-based XSS) manipule l'environnement DOM côté client sans interaction avec le serveur.

Les conséquences du XSS incluent le vol de cookies de session (pour le détournement de session), la redirection vers des sites malveillants (phishing), l'exécution d'actions au nom de la victime (CSRF facilité), et l'enregistrement des frappes clavier. Les contre-mesures incluent l'encodage des sorties (output encoding), la Content Security Policy (CSP), l'utilisation de l'attribut HttpOnly sur les cookies, et les frameworks modernes qui encodent automatiquement les variables dans les templates.

2.6 Cyber Kill Chain (Lockheed Martin, 2011) et MITRE ATT&CK

La Cyber Kill Chain modélise 7 étapes séquentielles. Interrompre l'attaque aux phases de Reconnaissance ou de Livraison est infiniment moins coûteux qu'en phase d'Action finale.

Comprendre l'anatomie d'une attaque est la condition sine qua non pour construire des défenses efficaces. Un défenseur qui ne connaît pas les méthodes de l'attaquant est condamné à réagir plutôt qu'à prévenir.

Figure 3 — Cyber Kill Chain — 7 phases d'une cyberattaque avancée (Lockheed Martin, 2011)

CYBER KILL CHAIN — 7 PHASES

1. Reconnaissance	Collecte d'informations sur la cible (OSINT, scan réseau, ingénierie sociale préparatoire). Sources : réseaux sociaux, WHOIS, Shodan, sites web.
2. Armement	Développement ou acquisition de l'arme cyber (exploit, malware, payload). Association d'un exploit à une charge utile (dropper + malware).
3. Livraison	Acheminement de l'arme vers la cible (pièce jointe email, lien malveillant, clé USB, site web compromis watering hole).
4. Exploitation	Déclenchement de l'exploit sur le système cible (exécution de code via vulnérabilité logicielle, action utilisateur).
5. Installation	Installation d'un accès persistant (backdoor, RAT, rootkit, tâche planifiée). L'attaquant s'ancre durablement.
6. Commande & Contrôle (C2)	Établissement d'un canal de communication entre le malware et l'infrastructure de l'attaquant pour piloter l'attaque à distance.
7. Action sur objectifs	Réalisation de l'objectif final : exfiltration de données, chiffrement (ransomware), sabotage, espionnage, pivotement vers d'autres systèmes, segmentation réseau, sauvegardes offline

Le framework MITRE ATT&CK (Adversarial Tactics, Techniques, and Common Knowledge), publié en 2015 et mis à jour régulièrement, est devenu la référence mondiale pour la description et la classification des techniques d'attaque réelles. Il répertorie plus de 600 techniques et sous-techniques organisées en 14 tactiques pour la matrice Enterprise (Windows, macOS, Linux, Cloud, Mobile, ICS). Chaque technique est documentée avec des exemples de groupes APT, des procédures de détection, et des contre-mesures. Defense Evasion (43 techniques) et Discovery (32 techniques) sont les plus denses, révélant les priorités des attaquants : rester furtifs et cartographier le terrain.

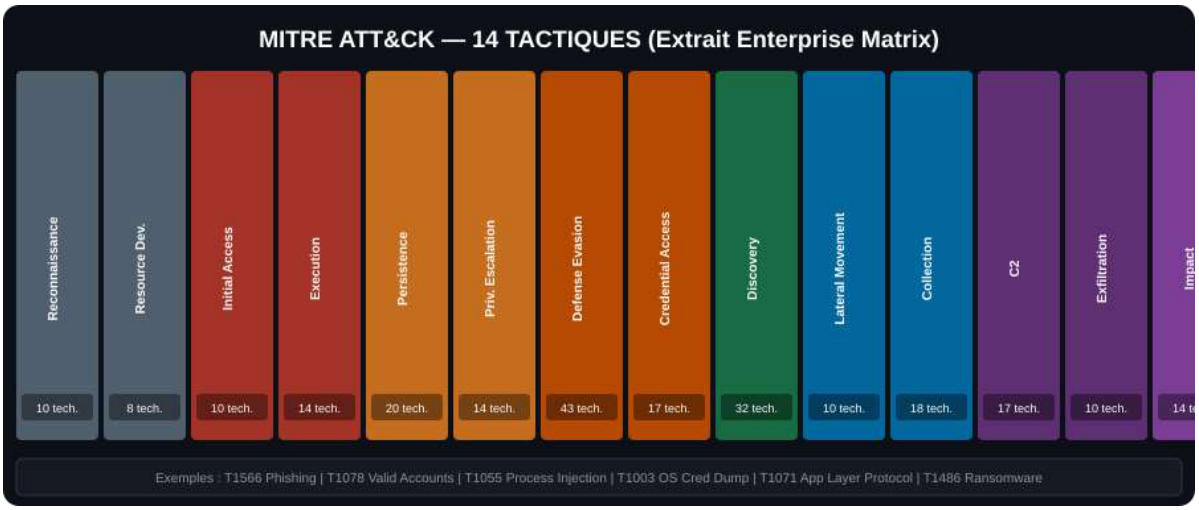

Figure 4 — MITRE ATT&CK — Les 14 tactiques de la matrice Enterprise

ATT&CK est utilisé par les équipes Red Team pour planifier des exercices de simulation d'attaques réalistes, par les équipes Blue Team pour évaluer leurs capacités de détection (ATT&CK coverage), par les équipes Threat Intelligence pour profiler les groupes d'attaquants, et par les architectes sécurité pour identifier les lacunes dans leurs défenses.

2.7 Menaces techniques majeures

2.2.1 Ransomware — La menace dominante

Le modèle Ransomware-as-a-Service (RaaS) fonctionne comme une franchise criminelle : des développeurs spécialisés créent l'infrastructure, des affiliés conduisent les intrusions et perçoivent 70-80 % de la rançon. La double extorsion (chiffrement + menace de publication) et la triple extorsion (pression sur les clients et partenaires) aggravent l'impact. Clop/MOVEit 2023 — 2 700+ organisations dans 70 pays, 100+ millions de personnes affectées — illustre l'ampleur possible.

Anatomie d'une attaque ransomware moderne
1. Accès initial : Exploitation de VPN/RDP vulnérables, phishing ciblé, achat d'accès initial (IAB) sur des forums cybercriminels.
2. Reconnaissance interne : Cartographie AD avec BloodHound/SharpHound, identification des sauvegardes, des DC, des systèmes critiques.
3. Mouvement latéral et élévation de privilèges : Pass-the-Hash, Kerberoasting, exploitation de vulnérabilités AD.
4. Persistence et exfiltration massive : RATs multiples, exfiltration vers cloud public — parfois des téraoctets.
5. Déploiement ransomware et sabotage des sauvegardes : Suppression des copies shadow, désactivation des logiciels de backup, chiffrement massif.

2.2.2 Ingénierie sociale et phishing

L'ingénierie sociale exploite les biais cognitifs humains (autorité, urgence, confiance, peur). Elle constitue le vecteur d'intrusion le plus fréquent (36 % selon Verizon DBIR 2024). Le BEC (Business Email Compromise) a causé 50 milliards de dollars de pertes mondiales entre 2013 et 2023. L'IA générative a provoqué un saut qualitatif : génération de phishing hyper-personnalisé à grande échelle, deepfakes audio et vidéo (virement frauduleux de 25 millions de dollars via vidéoconférence deepfake en 2024).

2.2.3 Menaces persistantes avancées (APT)

Les Advanced Persistent Threats désignent des acteurs malveillants — généralement étatiques ou parrainés par des États — caractérisés par leur niveau de sophistication élevé, leurs ressources importantes, leur persistance sur de longues périodes (mois ou années), et la spécificité de leurs cibles (gouvernements, industries stratégiques, organisations de défense). Leur caractéristique principale est la persistance : 9 mois non détectés pour SolarWinds (2020). Groupes documentés : APT28/Fancy Bear (GRU russe — ingérence électorale), APT29/Cozy Bear (SVR russe — SolarWinds), Lazarus Group (Corée du Nord — cybercriminalité financière, crypto), APT41 (Chine — espionnage étatique + cybercriminalité).

Contrairement aux cybercriminels opportunistes, les APT font preuve d'une discipline opérationnelle rigoureuse : utilisation d'exploits 0-day, développement de malwares sur-mesure, exfiltration lente et discrète pour éviter la détection, utilisation d'infrastructures éphémères. APT28 (Fancy Bear, attribué aux services de renseignement militaire russes GRU) a notamment été responsable des intrusions dans les systèmes du DNC américain en 2016, du Bundestag allemand en 2015, et de nombreuses organisations gouvernementales européennes.

La défense contre les APT nécessite une approche assume breach : partir du principe que l'attaquant a déjà pénétré le périmètre et concevoir les défenses en conséquence — surveillance

comportementale avancée (UEBA), chasse aux menaces (threat hunting), segmentation réseau empêchant le mouvement latéral, et plans de réponse aux incidents rodés.

A01 (Broken Access Control, 94 % des applications affectées) : IDOR, navigation forcée, élévation de privilèges horizontale. A03 (Injection SQL/LDAP/NoSQL) : requêtes construites par concaténation de chaînes. A06 (Vulnerable Components) : Log4Shell (CVE-2021-44228, CVSS 10.0) — une seule dépendance vulnérable dans des centaines de millions d'applications Java, exploitée massivement dans les 24h suivant la divulgation. Illustration parfaite du risque de la supply chain logicielle.

CHAPITRE 3 — LE CYBERESPACE : ANATOMIE D'UN ESPACE INÉDIT

INTRODUCTION

Avant de parler de risques, d'attaques ou de défenses, il est indispensable de comprendre l'objet que l'on cherche à protéger : le cyberespace. C'est un espace qui n'a pas d'équivalent dans l'histoire humaine — un territoire sans frontières physiques, construit en quelques décennies, qui structure aujourd'hui la totalité des activités économiques, politiques, sociales et militaires de notre monde.

Ce chapitre explore le cyberespace dans ses dimensions techniques (réseaux, protocoles, systèmes d'information, cloud, IoT), informationnelles (données, métadonnées, big data), et géopolitiques (enjeux de puissance, souveraineté numérique). Cette compréhension est la condition préalable à toute démarche de sécurité cohérente : on ne peut pas protéger ce qu'on ne comprend pas.

L'approche retenue s'inspire de la structuration proposée par Patrick Lallement : décrire d'abord les convergences technologiques qui ont construit le cyberespace, puis les systèmes d'information qui en sont les acteurs principaux, puis les données qui en sont la matière première, pour finalement saisir la dimension géopolitique de cet espace des possibles — et des dangers.

OBJECTIFS PÉDAGOGIQUES

- ✓ Comprendre l'architecture et les couches constitutives du cyberespace
- ✓ Décrire les convergences technologiques (numérique, internet, cloud, IoT) qui ont créé cet espace
- ✓ Analyser le système d'information comme actif central à protéger
- ✓ Comprendre les enjeux autour des données (personnelles, sensibles, métadonnées, big data)
- ✓ Saisir les dimensions géopolitiques du cyberespace et la notion de puissance numérique
- ✓ Identifier les systèmes cyber-physiques et les risques de l'interconnexion IT/OT

3.1 Qu'est-ce que le cyberespace ?

Le terme cyberespace a été popularisé par William Gibson dans son roman Neuromancer (1984) avant de devenir une réalité concrète et omniprésente. Aujourd'hui, le cyberespace désigne l'environnement global, dynamique et immatériel constitué par l'ensemble des infrastructures numériques interconnectées — réseaux, systèmes informatiques, logiciels, données — et des interactions humaines qui s'y déroulent.

Sa particularité fondamentale, qui le distingue de tout autre espace humain, est qu'il est à la fois global (sans frontières physiques définitives), construit (entièrement d'origine humaine, donc délibérément conçu), évolutif (en mutation permanente), et asymétrique (un acteur isolé peut y atteindre des millions de cibles à l'échelle planétaire depuis un laptop). Ces quatre caractéristiques expliquent à elles seules pourquoi la sécurité y est structurellement difficile.

3.1.1 Les quatre couches du cyberespace

Le cyberespace peut être analysé selon un modèle en quatre couches interdépendantes. Cette stratification est fondamentale pour la cybersécurité : une attaque peut traverser plusieurs couches simultanément, et les défenses doivent opérer à chaque niveau.

Couche	Description
Couche physique (L1)	L'infrastructure matérielle : câbles sous-marins (90 % du trafic mondial passe par les 426 câbles actifs en 2024), satellites, fibres optiques, antennes, datacenters, routeurs, serveurs. Cette couche est vulnérable aux attaques physiques et géopolitiques. L'incident des câbles en Mer Rouge (2024) illustre la fragilité de cette infrastructure.
Couche logique (L2)	Les protocoles et logiciels : TCP/IP, BGP, DNS, systèmes d'exploitation, applications. C'est à ce niveau qu'opèrent la majorité des cyberattaques (exploitation de vulnérabilités logicielles, empoisonnement DNS, détournement BGP). La couche logique est entièrement construite sur des standards ouverts conçus initialement pour la résilience, pas pour la sécurité.
Couche informationnelle (L3)	Les données, contenus et services applicatifs : messagerie, cloud, réseaux sociaux, systèmes bancaires, dossiers médicaux. C'est la couche qui a la valeur économique et stratégique la plus élevée pour les attaquants (exfiltration, falsification, destruction de données).
Couche sociale et cognitive (L4)	Les utilisateurs humains, leurs comportements, leurs biais cognitifs, leurs interactions. C'est la couche la plus exploitée par l'ingénierie sociale. 82 % des violations de données impliquent l'élément humain (DBIR 2024). L'individu est simultanément l'unité de base du SI et son maillon le plus vulnérable.

Commentaire : un incident de cybersécurité peut être initié dans la couche sociale (phishing ciblant un employé), se déployer dans la couche logique (exploitation d'une CVE non patchée), compromettre la couche informationnelle (exfiltration de données sensibles), et potentiellement

impacter la couche physique (paralysie d'un système industriel). La défense en profondeur doit couvrir les quatre couches simultanément.

3.2 Les convergences technologiques — Construction du cyberespace

Le cyberespace actuel est le résultat de plusieurs vagues de convergences technologiques qui se sont succédées depuis les années 1960. Chaque convergence a élargi la surface d'attaque potentielle tout en créant de nouvelles opportunités économiques. Comprendre cette histoire est indispensable pour comprendre pourquoi la sécurité n'a pas été intégrée dès le départ.

3.2.1 La convergence vers le tout-numérique

Dans les années 1960, l'information était en grande partie analogique : textes, musique, images, téléphone, TV. Depuis les années 2000, tout est numérisable. Cette première convergence — du signal analogique vers le signal numérique — a une conséquence majeure pour la sécurité : toute information, quelle que soit sa nature originelle, peut désormais être copiée, transmise, modifiée, interceptée ou détruite avec les mêmes outils informatiques. La barrière entre la sécurité physique (un document papier dans un coffre-fort) et la sécurité numérique s'est effondrée.

Jusqu'aux années 1980, les systèmes informatiques étaient fortement centralisés : mainframes exécutant l'ensemble des opérations, connexions limitées en nombre et en durée. Cette centralisation présentait un avantage sécuritaire : peu de points d'entrée, contrôles d'accès concentrés. La décentralisation progressive — micro-ordinateurs, réseaux locaux, Internet, cloud — a multiplié les surfaces d'attaque de façon exponentielle.

3.2.2 Internet — Un réseau conçu pour la résilience, pas pour la sécurité

Internet est l'aboutissement d'un projet né en pleine Guerre froide (ARPANET, 1964) dont l'objectif était la résilience des communications en cas d'attaque nucléaire. Les protocoles fondamentaux de TCP/IP ont été conçus dans les années 1970 avec un postulat de confiance mutuelle entre les acteurs du réseau — postulat raisonnable pour un réseau académique fermé, catastrophique à l'échelle d'un réseau mondial public.

Cette origine explique des vulnérabilités structurelles persistantes : IP est un protocole d'acheminement qui ne contrôle ni la perte de paquets ni leur intégrité ; BGP (le protocole de routage inter-domaines) repose sur la confiance entre les opérateurs et peut être détourné (BGP hijacking) ; DNS peut être empoisonné ; TCP est vulnérable aux attaques de déni de service. Ces vulnérabilités ne sont pas des bugs — elles sont des choix de conception qui ont privilégié l'efficacité sur la sécurité.

Protocole	Description
IP (Internet Protocol)	Protocole d'acheminement des paquets. Ne garantit pas la livraison. L'adresse source peut être falsifiée (IP spoofing), exploitable pour les attaques DDoS par réflexion/amplification.
TCP (Transmission Control Protocol)	Protocole de transport fiable (accusés de réception). Vulnérable aux attaques SYN flood (saturation de la table de connexions), aux attaques de reset TCP.
DNS (Domain Name System)	Résolution des noms de domaine en adresses IP. Vulnérable au cache poisoning (Kaminsky 2008), au DNS amplification (facteur x179 pour UDP 53), au DNS tunneling (exfiltration de données via requêtes DNS).

Protocole	Description
BGP (Border Gateway Protocol)	Routage inter-domaines (AS — Autonomous Systems). Repose sur la confiance entre opérateurs. Vulnérable au BGP hijacking (annonce frauduleuse de préfixes IP). RPKI/ROV apporte une validation cryptographique en déploiement progressif.
HTTP/HTTPS	Protocole applicatif du web. HTTP transmet en clair (toutes les données interceptables). HTTPS via TLS chiffre la communication. Migration vers TLS 1.3 prioritaire (suppression des algos faibles).
SMTP (messagerie)	Protocole de transfert d'emails, conçu sans authentification de l'expéditeur. SPF, DKIM et DMARC ont été ajoutés pour lutter contre la falsification des expéditeurs (spoofing).

3.2.3 Le web — Moteur de l'exposition des systèmes

Le web, inventé par Tim Berners-Lee en 1990 au CERN, est l'application qui a démocratisé Internet et déclenché le développement exponentiel des services en ligne. Son évolution en trois générations — Web 1.0 (lecture statique), Web 2.0 (participation, écriture collaborative), Web 3.0 (décentralisation, blockchain, données sémantiques) — a à chaque étape élargi la surface d'attaque.

Le Web 2.0 a introduit des paradigmes majeurs pour la sécurité : la syndication de contenu (RSS-XML), l'étiquetage social (tags), les API REST (devenues aujourd'hui le premier vecteur d'attaque des applications modernes selon Gartner), les plateformes d'écriture collaborative (wikis, Google Docs — qui posent des questions de classification des données et de contrôle d'accès). Chaque service web exposé est potentiellement un point d'entrée.

3.2.4 Le dark web — La face cachée du cyberespace

Le dark web désigne la partie d'Internet non indexée par les moteurs de recherche et accessible uniquement via des logiciels spéciaux comme Tor (The Onion Router). Il ne représente qu'une infime partie du web total mais constitue une infrastructure critique de la cybercriminalité : marchés de vente de données volées, de malwares, de credentials compromis, de services de ransomware (RaaS), de services de blanchiment de cryptomonnaies.

La distinction entre surface web (indexé, accessible publiquement), deep web (non indexé mais légal — bases de données privées, intranets, messageries) et dark web (non indexé, accessible via Tor, souvent illicite) est importante pour les équipes de threat intelligence : le monitoring du dark web permet d'anticiper les attaques ciblées en détectant la vente de données d'une organisation avant même qu'elle n'ait découvert la violation.

3.3 Le système d'information — L'actif central à protéger

Le système d'information (SI) est l'ensemble des ressources informatiques, organisationnelles et humaines qui permettent de collecter, stocker, traiter, diffuser et utiliser l'information nécessaire aux activités d'une organisation. Il n'est pas seulement une ressource technique — il est le système nerveux de l'entreprise. Toute atteinte au SI a un impact direct sur les processus métier, les clients, les partenaires et la réputation.

Cette perspective — le SI comme ressource de support aux activités métier, pas comme fin en soi — est fondamentale pour la cybersécurité. Elle oblige à raisonner en termes d'actifs (ce qu'il faut

protéger), de processus (ce qui doit continuer à fonctionner), et d'impacts métier (ce qu'on perd si on est attaqué) plutôt qu'en termes purement techniques.

3.3.1 Les fonctions du SI et les processus métier

Un système d'information sert quatre fonctions fondamentales : collecter les données (capteurs, formulaires, interfaces), stocker les données (bases de données, fichiers, archives), traiter les données (calculs, transformations, décisions), et diffuser l'information (rapports, dashboards, communications). Chacune de ces fonctions est un potentiel vecteur d'attaque : la collecte peut être détournée (injection de données falsifiées), le stockage peut être exfiltré ou chiffré, le traitement peut être perturbé (modification des algorithmes), la diffusion peut être interceptée ou falsifiée.

Les processus métier — production, logistique, commercial, finances, RH — sont tous traversés par des flux d'information gérés par le SI. Les outils centraux incluent : les ERP (Enterprise Resource Planning — gestion intégrée de toutes les ressources), les outils de workflow (automatisation des procédures), les outils collaboratifs (espaces de travail partagés), et les systèmes de messagerie. La compromission d'un ERP (SAP, Oracle) ou d'une messagerie (Microsoft Exchange, Office 365) peut paralyser l'intégralité des opérations d'une organisation.

3.3.2 La dimension humaine du SI

L'être humain est à la fois l'unité de base et le maillon le plus vulnérable du SI. Cette dualité fondamentale — l'humain comme acteur indispensable ET comme vecteur d'attaque privilégié — doit structurer toute politique de sécurité.

L'humain présente des caractéristiques qui le rendent vulnérable aux attaques d'ingénierie sociale : il ne peut traiter que 7 données simultanément (alors que la machine n'a pas de limite), il est soumis à la fatigue et aux biais cognitifs (autorité, urgence, confiance), il peut improviser dans des situations nouvelles (avantage sur la machine) mais peut aussi être trompé par des scénarios plausibles. Les attaques d'ingénierie sociale exploitent systématiquement ces caractéristiques. La formation et la sensibilisation sont donc des contrôles de sécurité au même titre qu'un firewall.

3.3.3 L'infrastructure réseau du SI

L'infrastructure réseau d'une entreprise est constituée d'une infrastructure locale (LAN — Local Area Network) et de ressources fournies par les opérateurs télécoms : accès à Internet, interconnexion des sites (WAN), accès distant pour les itinérants (VPN), accès aux ressources cloud. L'indisponibilité du réseau peut avoir un effet très pénalisant selon le degré d'exposition aux ressources externes.

Une configuration de base d'un poste de travail pour accéder aux services réseau requiert : l'adresse IP du poste et le masque associé, l'adresse IP de la passerelle (routeur), l'adresse IP du serveur DNS, et l'adresse IP du serveur DHCP. Cette configuration minimale révèle les dépendances critiques : si le DNS est compromis ou indisponible, l'ensemble des services nominaux par leur nom est inaccessible. Les serveurs publics (web, messagerie, DNS) sont exposés à Internet et constituent des cibles prioritaires.

3.3.4 Virtualisation et cloud computing

La virtualisation — créer des machines virtuelles (VM) à partir d'une machine réelle via un hyperviseur — a révolutionné l'administration des SI en réduisant les coûts matériels, simplifiant l'administration et permettant la restauration rapide après défaillance. Mais elle crée aussi de nouveaux risques : une défaillance au niveau hôte impacte toutes les VM qui y résident, et les VM peuvent être exportées (vol de l'image disque complète d'un serveur).

Le cloud computing pousse la virtualisation à son extrême en déplaçant les ressources hors de l'entreprise, chez un prestataire (IaaS, PaaS, SaaS). Le modèle de responsabilité partagée (Shared Responsibility Model) distribue les responsabilités de sécurité entre le fournisseur (infrastructure physique, hyperviseur) et le client (configurations, données, applications). La principale cause de violations cloud : les mauvaises configurations (buckets S3 publics, IAM trop permissifs) — pas les vulnérabilités de l'infrastructure cloud elle-même.

Modèle cloud	Description
IaaS (Infrastructure as a Service)	Ressources de calcul, stockage, réseau à la demande. Le client gère OS, middleware, applications. Exemples : AWS EC2, Azure VM, GCP Compute Engine. Responsabilité sécurité : tout ce qui est au-dessus de l'hyperviseur.
PaaS (Platform as a Service)	Plateforme de développement et de déploiement. Le fournisseur gère l'OS et le middleware. Le client gère les applications et les données. Exemples : Heroku, Google App Engine, Azure App Service.
SaaS (Software as a Service)	Application complète fournie en service. L'utilisateur accède via navigateur. Le fournisseur gère tout sauf les données et les accès utilisateurs. Exemples : Microsoft 365, Salesforce, Google Workspace.
SecNumCloud (France)	Qualification de l'ANSSI pour les services cloud de confiance. Garantit la protection contre les lois extra-territoriales (CLOUD Act US). OVHcloud et Outscale sont les acteurs principaux.
CASB (Cloud Access Security Broker)	Passerelle de sécurité entre les utilisateurs et les services cloud. Visibilité sur l'usage du cloud, contrôle des accès, protection des données. Répond au risque du Shadow IT (usages cloud non autorisés).
CSPM (Cloud Security Posture Management)	Détection en continu des dérives de configuration cloud (buckets publics, IAM trop permissifs). Outils : Prisma Cloud, AWS Security Hub, Microsoft Defender for Cloud.

3.4 Les systèmes cyber-physiques — Quand le numérique contrôle le réel

Les systèmes cyber-physiques (CPS — Cyber-Physical Systems) désignent des systèmes où des composants informatiques (logiciels, réseaux, algorithmes) interagissent en temps réel avec des composants physiques (actionneurs, capteurs, processus industriels). La frontière entre le monde numérique et le monde physique est ici abolie : une action dans le cyberespace peut avoir des conséquences physiques immédiates.

Cette convergence IT/OT (Information Technology / Operational Technology) crée la surface d'attaque la plus préoccupante de la cybersécurité contemporaine. Industroyer/Crashoverride (2016) a provoqué une coupure d'électricité en Ukraine en contrôlant directement des équipements électriques industriels via des protocoles ICS natifs. Triton/TRISIS (2017) a ciblé les Safety Instrumented Systems d'une raffinerie pétrolière en Arabie saoudite, avec pour objectif potentiel de provoquer une explosion physique. L'incident de Fukushima illustre l'effet domino inverse : un accident physique (séisme, tsunami) qui compromet les systèmes de contrôle informatiques, provoquant à son tour un accident physique majeur (explosion nucléaire).

3.4.1 L'Internet des Objets (IoT)

L'IoT connecte des milliards d'appareils physiques au cyberespace : caméras de surveillance, thermostats, équipements médicaux, véhicules connectés, capteurs industriels, compteurs intelligents. Cette extension massive du cyberespace vers le monde physique crée des défis spécifiques qui rendent la sécurité structurellement difficile.

Défi IoT	Description
Contraintes ressources	CPU, mémoire et énergie limités. Impossibilité d'implémenter les mécanismes cryptographiques habituels ou d'héberger des agents de sécurité. Un thermostat connecté n'a pas la puissance de calcul nécessaire pour un TLS complet.
Cycles de vie longs	20-30 ans pour les équipements industriels. Impossible de patcher régulièrement. Des équipements médicaux ou des automates conçus avant l'ère de l'IoT sont maintenant connectés à Internet.
Fragmentation extrême	Milliers de fabricants, protocoles propriétaires (Modbus, Profibus, BACnet, DNP3, Zigbee, LoRaWAN) conçus avant l'ère de la sécurité. Absence de standards de sécurité communs.
Credentials par défaut	admin/admin, 1234, password — souvent identiques pour des milliers de modèles identiques. Mirai (2016) a compromis 300 000 caméras IP avec ces identifiants par défaut, générant l'attaque DDoS record de 1,1 Tbit/s contre Dyn DNS.
Absence de mise à jour	Pas d'interface de mise à jour dans de nombreux appareils IoT. Les vulnérabilités découvertes restent souvent non corrigées pendant toute la durée de vie de l'appareil.
Sécurité physique limitée	Un attaquant ayant accès physique à un objet connecté peut souvent extraire les credentials ou le firmware. La sécurité physique est rarement intégrée.

La norme IEC 62443 est le cadre de référence international pour la sécurité des systèmes industriels. Le modèle de Purdue (5 niveaux : enterprise, DMZ, supervision, contrôle, terrain) recommande une ségrégation stricte des niveaux OT/IT avec une DMZ intermédiaire.

3.5 Un univers de données — La matière première du cyberespace

Les données sont à la fois l'actif principal à protéger et la motivation première des attaquants. Comprendre la nature, la classification et les cycles de vie des données est indispensable pour concevoir une protection adéquate.

3.5.1 Donnée vs information — Une distinction fondamentale

La donnée est définie par une sémantique et une valeur. Elle est indépendante de l'application qui l'utilise et du fichier qui la contient. Elle a un format pour être stockée, traitée, affichée. L'information est le résultat de l'interprétation d'une ou plusieurs données dans un contexte. Un ensemble de chiffres bruts (données) interprété dans un contexte financier devient une information sur la trésorerie d'une entreprise. Cette distinction est importante : c'est souvent la combinaison de

données anodines qui révèle des informations sensibles (corrélation de données de géolocalisation + historique d'achats = profil comportemental).

3.5.2 Classification des données

La classification des données est la condition préalable à toute politique de sécurité cohérente. On ne peut pas protéger ce qu'on ne sait pas identifier. Une classification efficace doit être simple (4 niveaux maximum), comprise par tous les collaborateurs, et intégrée aux outils de travail.

Niveau de classification	Description
Public	Données accessibles à tous, sans restriction. Aucune mesure de protection particulière requise. Exemples : plaquettes commerciales, communiqués de presse, données de contact génériques.
Interne / Usage interne	Données réservées aux collaborateurs. Ne doivent pas être diffusées à l'extérieur. Exemples : procédures internes, organigrammes, plans de projets non sensibles. Protection : contrôle d'accès basique, pas de diffusion externe.
Confidentiel	Données sensibles dont la divulgation causerait des dommages significatifs. Exemples : données financières non publiées, propriété intellectuelle, données personnelles, accords commerciaux. Protection : chiffrement, accès restreint, traçabilité.
Secret / Très confidentiel	Données dont la divulgation causerait des dommages graves ou irréversibles. Exemples : plans stratégiques, informations sur des vulnérabilités non corrigées, données de défense nationale. Protection maximale : chiffrement, cloisonnement, audit d'accès systématique.

3.5.3 Les données personnelles — Un enjeu réglementaire majeur

Une donnée personnelle est une donnée qui permet d'identifier une personne en particulier : état civil, adresse, numéro de téléphone, numéro de sécurité sociale, adresse IP (même dynamique), photo, vidéo, dossier médical, enregistrement de la voix, coordonnées GPS. Cette définition extensive du RGPD signifie que presque toute organisation collecte des données personnelles.

La question critique : où sont les données personnelles ? Dans toute entreprise, elles sont présentes dans les ressources humaines (employés, stagiaires), les services juridiques (clients, fournisseurs), les services commerciaux (clients), les services financiers (actionnaires). Des espaces de stockage souvent ignorés constituent des risques : les photocopieurs et imprimantes conservent sur leur disque dur interne une copie PDF de tout document copié ou imprimé. À la fin du cycle de vie de l'appareil, ce disque doit être physiquement détruit avant cession.

3.5.4 Les métadonnées — La fuite de données silencieuse

Un fichier comprend les données (partie utile) et des métadonnées. Les métadonnées renseignent sur le "quoi" des données — elles sont souvent ignorées alors qu'elles peuvent contenir des informations très sensibles.

Les métadonnées générales incluent : nom, type, taille, dates de création/modification/accès. Les métadonnées descriptives : titre, objet, mots-clés, commentaires. Les métadonnées d'origine :

auteur, dernier enregistrement, numéro de version, nom du programme, entreprise. Les métadonnées Exif des photos : caractéristiques de l'appareil photo, paramètres de prise de vue, et surtout les coordonnées GPS et l'horodatage — qui révèlent précisément où et quand une photo a été prise. De nombreuses fuites d'information stratégique ont été réalisées via des métadonnées non nettoyées dans des documents publiés en ligne. Des outils comme ExifTool permettent d'extraire et de modifier (voire de falsifier) ces métadonnées.

3.5.5 Le big data — La révolution des données à grande échelle

Le concept de big data est défini par trois caractéristiques (les 3V) : Volume (too big — des pétaoctets de données), Vitesse (too fast — traitement en temps réel), Variété (too hard — formats hétérogènes : texte, image, son, statistiques, signaux). Le big data est à l'origine d'une révolution épistémologique : auparavant on construisait des modèles à partir de peu de données ; maintenant on construit des modèles par apprentissage à partir de quantités faramineuses de données sans modèle a priori.

L'utilisation principale des technologies de big data : constitution de profils comportementaux (citoyen, consommateur, patient). Ces profils ont une valeur marchande considérable — et constituent donc une cible de choix pour les attaquants. La violation de données de santé (incluant des données big data de patients) peut rapporter jusqu'à 1 000 dollars par dossier sur les marchés cybercriminels, contre 10-20 dollars pour un numéro de carte bancaire.

3.6 Vers le cyberespace — Dimension géopolitique et enjeux de puissance

Dans les années 2000, Internet était un environnement universel auto-régulé, sans frontières, moteur de la bulle économique numérique. En 2024, il y a plus de 5 milliards d'internautes, dont environ 1 milliard de Chinois contre 280 millions d'Américains. Les 250 millions d'internautes de 2000 sont devenus 5 milliards, reflet du poids démographique des pays. Tous les systèmes d'information sont interconnectables — de proche en proche, le réseau des interdépendances atteint l'échelle monde. Chaque entreprise est ainsi potentiellement atteignable depuis n'importe quel point du globe.

3.6.1 La notion de puissance numérique

Le cyberespace dépasse l'échelle technique pour devenir un enjeu de puissance entre États. Pour la défense américaine, le cyberespace est devenu le 5ème espace de bataille (après la terre, la mer, le ciel et l'espace). Les États peuvent être évalués selon 4 leviers de puissance numérique :

- Les infrastructures télécoms : points d'échange Internet (IXP), connectivité internationale, datacenters — ceux qui contrôlent les câbles sous-marins et les grands IXP contrôlent les flux d'information mondiale.
- Les capacités scientifiques et technologiques : centres de recherche en cybersécurité, brevets, publications académiques, compétences des talents formés.
- La base industrielle et technologique : industrie du composant hardware (dominée par les États-Unis, Taïwan, Corée du Sud, Japon, Chine), du logiciel (dominée par les États-Unis), des services cloud (AWS, Azure, GCP — tous américains).
- Le niveau de sécurité et de régulation du réseau, les capacités de cyberdéfense offensive et défensive.

3.6.2 La souveraineté numérique — Un enjeu stratégique

La souveraineté numérique désigne la capacité d'un État ou d'une organisation à maîtriser ses données et ses technologies. Elle est menacée par plusieurs vecteurs : la dépendance aux

fournisseurs cloud américains (CLOUD Act — autorisation des autorités US d'accéder aux données hébergées par des sociétés américaines même hors des États-Unis), la dépendance aux composants hardware (processeurs, mémoires — domination taïwanaise et coréenne), et la dépendance aux logiciels (systèmes d'exploitation, applications — domination américaine).

Les réponses européennes et françaises à ces enjeux : la doctrine cloud de confiance de l'État français (qualification SecNumCloud de l'ANSSI), le projet GAIA-X européen (infrastructure de données souveraine), les investissements dans les acteurs souverains (OVHcloud, Outscale/Dassault Systèmes), et les réglementations sur les données (RGPD, Data Governance Act, Data Act). La tension entre l'efficacité économique (utiliser les meilleurs outils disponibles, souvent américains) et la souveraineté (contrôler ses données) est le dilemme central de la politique numérique européenne.

3.6.3 La densification du cyberespace et les effets de bord

L'effet de propagation est l'une des caractéristiques les plus déstabilisantes du cyberespace. En 2017, les attaques WannaCry et NotPetya ont touché des centaines de milliers de machines dans le monde entier. L'attaque NotPetya, visant initialement l'Ukraine via l'infection d'un logiciel de comptabilité local, a infecté des milliers de machines mondiales quelques heures plus tard — illustrant que l'attaquant ne maîtrise pas les effets domino de ce qu'il déclenche.

Cette densification du cyberespace signifie que les interconnexions entre systèmes d'information créent des trajectoires d'attaque imprévisibles. Une entreprise peut être compromise non pas directement, mais via un fournisseur, un sous-traitant, un partenaire (attaque de la supply chain). Les écosystèmes interconnectés — fournisseurs, partenaires, distributeurs, SI respectifs — constituent autant de vecteurs d'attaque potentiels. SolarWinds (2020) en est l'illustration la plus frappante : 18 000 organisations compromises via un seul éditeur de logiciels.

CHAPITRE 4 — L'ESPACE DES RISQUES : ANATOMIE DE LA MENACE CYBER

INTRODUCTION

L'espace des risques est le cœur analytique de la cybersécurité. C'est ici que se construit le cadre conceptuel qui permet de passer du sentiment vague d'insécurité à une analyse rigoureuse et opérationnelle des menaces. Sans cette compréhension, toute démarche de sécurité reste empirique et réactive — on réagit aux incidents au lieu de les anticiper.

Ce chapitre définit et articule les concepts fondamentaux : qu'est-ce qu'un risque, un cyber-risque, une menace, une attaque, un vecteur d'attaque, une vulnérabilité, un exploit, un impact ? Comment ces concepts s'articulent-ils dans une chaîne causale allant de la malveillance potentielle aux dommages réels ? Comment le responsable de la sécurité peut-il agir sur chaque maillon de cette chaîne ?

La rigueur conceptuelle est ici indispensable. Le mot « risque » est l'un des plus mal utilisés du langage courant : on confond risque et probabilité, risque et danger, risque et menace. Cette confusion conceptuelle conduit à des décisions de sécurité mal calibrées et à des investissements inadaptés. La formule du risque — R = p × D (probabilité × dommage) — est simple mais sa décomposition en facteurs d'action est ce qui permet au RSSI de savoir où concentrer ses efforts.

OBJECTIFS PÉDAGOGIQUES

- ✓ Définir rigoureusement le risque (formule, structure d'espérance mathématique) et distinguer risque, probabilité, danger, menace
- ✓ Identifier et distinguer les quatre types de cyber-risques (malveillant, technologique, physique, humain/organisationnel)
- ✓ Comprendre les critères DICP et leur application à l'évaluation des risques sur les données et les systèmes
- ✓ Analyser la chaîne causale de la menace aux dommages (décomposition en 5 termes probabilistes p1 à p5)
- ✓ Caractériser et classifier les menaces, les attaquants, leurs motivations et leurs cibles
- ✓ Maîtriser le processus de gestion des risques (identification, estimation, évaluation, traitement) et les méthodes EBIOS RM, MEHARI, ISO 27005

4.1 Qu'est-ce que le risque ? Fondements théoriques

Le risque est l'un des concepts les plus universellement mal compris et mal utilisés. Dans le langage courant, on entend régulièrement des expressions erronées comme « risque d'incendie » ou « risque de tremblement de terre ». Ces expressions sont incorrectes : un incendie ou un tremblement de terre sont des événements (des causes), pas des risques. Un risque désigne le résultat potentiel d'un événement, c'est-à-dire les dommages qu'il pourrait causer. On devrait dire : « risque lié à un incendie » ou « risque lié à un tremblement de terre ».

Cette distinction entre les causes et les effets est fondamentale pour la gestion des risques : les traitements préventifs pour limiter les risques ne sont pas du tout les mêmes selon qu'on agit sur la cause (probabilité) ou sur l'effet (dommage). Un professionnel qui confond risque et probabilité conçoit des politiques de sécurité inadaptées.

4.1.1 Définition formelle du risque

Le risque est défini par le triplet (Si, pi, Di) où :

- Si est un scénario redouté (l'événement potentiel)
- pi est la probabilité que ce scénario survienne
- Di mesure les dommages causés si ce scénario se réalise

Le risque se mesure de façon suivante : Ri = pi × Di. Cette formule a une structure d'espérance mathématique — elle représente la valeur attendue des dommages. Son interprétation stratégique est immédiate : idéalement, les événements les plus probables doivent être ceux qui conduisent aux dommages les plus faibles ; et les dommages les plus grands doivent être associés aux probabilités les plus faibles.

Risque ≠ Probabilité — Une distinction cruciale
ERREUR COURANTE : "Il y a un risque d'incendie dans notre datacenter." → Cette formulation confond la cause (incendie) et le risque (dommages causés par l'incendie).
FORMULATION CORRECTE : "Le risque lié à un incendie dans notre datacenter est élevé en raison de l'absence de système sprinkler et de la présence de câbles mal organisés."
CONSÉQUENCE PRATIQUE : Si on traite le "risque d'incendie" comme une probabilité seule, on investit uniquement dans la détection (sprinkler, alarme). Si on le traite correctement comme p × D, on investit aussi dans la réduction des dommages (sauvegardes hors site, plan de continuité, assurance) — même si l'incendie reste peu probable.
Dans la formule du risque, les causes sont représentées par p et les effets par D. Ne jamais confondre les deux.

4.1.2 L'évaluation du risque

L'évaluation du risque nécessite d'estimer deux paramètres. Le terme p (probabilité ou vraisemblance) peut être évalué de façon quantitative (mesures statistiques, calculs probabilistes, simulations — approche du monde industriel) ou qualitative (échelle de 1 à 4 : peu probable, assez probable, probable, très probable — approche pragmatique en cybersécurité). Le terme D (dommage ou impact) est évalué en termes de temps d'interruption ou de coût financier — les deux seules grandeurs sommables permettant de comparer des causes très différentes.

En pratique, comme on ne peut pas couvrir tous les risques, il est crucial de les hiérarchiser. La représentation graphique p × G (courbe iso-risque) permet de visualiser tous les risques identifiés et de fixer un seuil d'acceptabilité. Les risques au-dessus de ce seuil doivent être traités en priorité.

4.1.3 La sûreté de fonctionnement vs la cybersécurité

La sûreté de fonctionnement (SdF) est une discipline qui s'intéresse aux pannes et à la réparation des systèmes. Elle utilise les critères FMDS (Fiabilité, Maintenabilité, Disponibilité, Sécurité). La disponibilité A = MTBF/(MTBF + MTTR) est le critère partagé entre la SdF et la cybersécurité.

Attention à une confusion terminologique fréquente entre les domaines industriel et informatique. Dans le domaine industriel : la sécurité est liée à la notion d'accident, et la sûreté est liée à la malveillance. Dans le domaine informatique, c'est l'inverse : la sécurité est associée à la malveillance tandis que la sûreté (safety) désigne l'accident. Cette inversion peut créer des malentendus dans les projets de convergence IT/OT.

4.2 Le cyber-risque — Une composante transversale du risque global

Le risque global d'une entreprise est multi-factoriel : risque financier, technologique, juridique, social, environnemental, sûreté. Le risque cyber est une nouvelle composante de ce risque global — mais il n'est pas indépendant des autres. Il les impacte presque toutes. Une cyberattaque réussie peut :

- Impacter le risque financier (coûts de remédiation, amendes réglementaires, pertes d'exploitation)
- Impacter le risque juridique (violation du RGPD, responsabilité des dirigeants sous NIS2)
- Impacter le risque commercial (perte de clients, atteinte à la réputation)
- Impacter le risque de sûreté : dans le domaine industriel (Seveso notamment), une cyberattaque peut provoquer un accident physique aux conséquences environnementales majeures

Les technologies numériques ayant un effet structurant sur tous les processus de l'entreprise, toute atteinte au SI a un impact potentiel sur toutes les activités qu'il alimente.

4.2.1 Typologie du cyber-risque — Les quatre origines

Type de risque	Description
R1 — Malveillance (cyber-attaques)	Le risque caractéristique de la cybersécurité. La malveillance peut être externe (attaquants distants, APT, cybercriminels) mais aussi interne (employés mécontents, ex-collaborateurs, sous-traitants malveillants). C'est sur R1 que se concentre l'essentiel de cet ouvrage.
R2 — Risque technologique (SdF)	Lié à la fiabilité des technologies : défaillance matérielle (disque dur, serveur), défaillance logicielle (bug, corruption de données), indisponibilité d'un opérateur télécoms. Relève de la sûreté de fonctionnement. Conséquence principale : perte de données ou interruption de service.
R3 — Risque physique (accidents)	Endommagement ou destruction du SI par accident : dégât des eaux, incendie, inondation, séisme, foudre. Relève de la sûreté au sens industriel. Plan de continuité et sauvegardes off-site sont les principales contre-mesures.
R4 — Risque humain/organisationnel	Mauvaises pratiques, maladresses, absence de prise en compte du danger, baisse de vigilance, défaut de veille. Relève des procédures qualité. Erreur humaine : perte de

Type de risque	Description
	fichier, mauvais paramétrage, faux positif ignoré, mauvaise décision en situation de crise.

Important : ces quatre types de risques ne sont pas mutuellement exclusifs et peuvent se combiner. Une erreur humaine (R4 — mauvaise configuration d'un firewall) peut créer une vulnérabilité exploitée par un attaquant malveillant (R1). Un incident malveillant (R1 — ransomware) peut déclencher un risque de sûreté (R3 — arrêt d'un processus industriel critique).

4.2.2 Les critères DICP — Extension de la triade CIA

Dans le monde de la cybersécurité, on utilise les critères DICP pour évaluer les risques sur les données et les systèmes. La Disponibilité est le seul terme en commun avec le monde de la sûreté de fonctionnement.

Critère DICP	Description
D — Disponibilité	La donnée doit être accessible quand on en a besoin. Mesurée par A = MTBF/(MTBF + MTTR). S'applique aux données, aux serveurs, aux services réseau. Une attaque DoS ou un ransomware atteint directement la disponibilité.
I — Intégrité	La donnée ne doit pas avoir été altérée ou détruite par une entité non autorisée. Le hachage cryptographique (SHA-256) permet de vérifier l'intégrité. La falsification de données de contrôle industriel est la menace la plus grave sur l'intégrité.
C — Confidentialité	La donnée ne doit être accessible qu'aux personnes autorisées. Le chiffrement (AES-256 au repos, TLS en transit) est le mécanisme principal. Les contrôles d'accès (RBAC, ABAC) limitent qui peut accéder à quoi.
P — Preuve	Permet de retrouver les circonstances d'un changement d'état de la donnée. Implique la traçabilité des actions (logs), l'authentification des utilisateurs (MFA), l'imputabilité du responsable de l'action. Fondamentale pour la forensique et la conformité réglementaire.

4.2.3 Le risque sûreté (safety) — Quand le cyber tue

Le risque sûreté (safety risk) concerne les risques sur les biens et les personnes causés par un cyber-incident. Il se produit quand une cyberattaque perturbe les données de contrôle des processus cyber-physiques (rupture d'intégrité des données transmises), provoquant un effet domino entre monde logique (qui contrôle) et monde physique (contrôlé).

Exemples documentés : en 2014, une usine métallurgique allemande a été sévèrement endommagée à partir d'un mail et d'une pièce jointe. En 2020, l'hôpital universitaire de Düsseldorf a subi une attaque ransomware qui a contraint l'établissement à refuser les urgences pendant plusieurs jours — une patiente nécessitant des soins urgents est décédée après avoir été réorientée vers un hôpital à 30 km. En 2021, une usine de traitement des eaux en Floride a vu son niveau de NaOH (soude caustique) modifié à distance par un attaquant via TeamViewer. Ces incidents ne sont plus de la science-fiction.

4.3 Caractérisation du danger — De la menace aux dommages

Dans la formule du risque, le terme p peut être explicitement décomposé en 5 termes probabilistes, permettant d'identifier précisément où le responsable de la sécurité peut intervenir :

R = p1 × p2 × p3 × p4 × p5 × D, où :

- p1 : probabilité que le système soit menacé
- p2 : probabilité d'une action malveillante, sachant que le système est menacé
- p3 : probabilité qu'une vulnérabilité soit exploitée, sachant que le système est attaqué
- p4 : probabilité que la cible soit atteinte, sachant qu'une vulnérabilité a été exploitée
- p5 : probabilité que des dommages soient causés, sachant que la cible a été atteinte

Cette décomposition est stratégiquement essentielle : le responsable de la sécurité ne peut pas réduire p1 et p2 — il ne maîtrise pas l'existence ni les motivations de l'attaquant. Son périmètre d'action est p3, p4, et p5. Réduire p3 : identifier et corriger les vulnérabilités (patch management, hardening). Réduire p4 : segmenter le réseau pour limiter les chemins d'attaque internes, déployer la détection (SIEM, EDR). Réduire p5 : avoir une procédure de réponse aux incidents efficace, des sauvegardes testées permettant de limiter l'impact.

Par contre, si le responsable sécurité ne peut pas réduire la menace, il peut chercher à mieux la connaître — c'est l'intelligence de la menace (Threat Intelligence) : qui sont les attaquants potentiels, leurs motivations, leurs modes d'action habituels, leurs outils. Ces renseignements permettent de prendre des mesures préventives adaptées au profil de cette menace.

4.3.1 La menace — Caractérisation des attaquants

La menace correspond à la malveillance potentielle. Contrairement au danger industriel qui est caractérisé par le hasard, la menace cyber est caractérisée par la motivation. Les motivations expliquent les types d'attaques et les cibles privilégiées.

Motivation	Description
Gain financier (direct)	La motivation la plus courante. Fraude directe, rançongiciel (paiement de rançon en cryptomonnaie), vol de données bancaires, escroqueries BEC. Concerne potentiellement toutes les organisations.
Gain financier (indirect)	Vol de données revendables : données médicales (1 000 $/dossier), données de cartes bancaires (10-20 $), secrets industriels (valeur variable). Espionnage industriel commandité par des concurrents.
Cyberespionnage étatique	Collecte de renseignements stratégiques, militaires, diplomatiques. Acteurs : APT étatiques (APT28, APT29, APT41, Lazarus). Cibles : ministères, défense, industries stratégiques, think tanks.
Hacktivisme	Actions de groupes de cyber-activistes ciblant des organisations dont les valeurs ne correspondent pas aux leurs. Motivation : nuire à la réputation, souvent en publiant des données confidentielles. Cibles : nuclear, pétrolier, bancaire, groupes controversés.
Menace interne	Salariés, sous-traitants, partenaires mécontents. Motivation : vengeance personnelle. Dangereux car ils disposent d'accès

Motivation	Description
	légitimes (même limités), d'une connaissance de l'organisation, et d'un temps d'action potentiellement long avant détection.
Terrorisme / déstabilisation	Attaques de grande ampleur visant des systèmes administratifs ou d'importance vitale, à des fins de blocage ou de destruction. Menace de niveau étatique ou para-étatique. Exemple : attaques massives contre l'Estonie en 2007.

4.3.2 Attaque, vecteur d'attaque et scénarios

L'attaque désigne le passage à l'acte de la menace : les actions concrètes pour porter atteinte à la sécurité des données, des services, des biens ou des personnes. Une attaque peut être longue quand elle s'inscrit dans la durée (exfiltration de données, cyber-espionnage) — ce qui implique qu'elle ait été conçue pour rester furtive, non détectable par l'utilisateur ou par le système de surveillance.

Le vecteur d'attaque désigne le point d'entrée exploité pour initier l'attaque. Les vecteurs classiques incluent : la clé USB (introduction physique d'un malware en interne), le courriel de phishing (pièce jointe malveillante ou lien URL actif), le point d'eau (infection d'un site web couramment visité par la cible), l'exploitation directe de vulnérabilités exposées sur Internet (VPN, RDP, serveur web), et les fournisseurs tiers (supply chain attack via un logiciel ou un prestataire compromis).

Le scénario représente la stratégie de l'attaquant pour atteindre son but, combinant plusieurs étapes et plusieurs vecteurs. Un scénario peut se dérouler sur le temps long (semaines, mois) — les attaques APT opèrent souvent sur des années avant leur détection. À chaque étape, les techniques varient pour que l'attaque reste non détectable.

4.3.3 Les 14 tactiques MITRE ATT&CK — Cartographie des scénarios

La matrice MITRE ATT&CK, développée par la corporation MITRE à partir de 2013, est aujourd'hui le référentiel mondial de modélisation des attaques. Elle recense 14 tactiques et plus de 600 techniques, chacune documentée avec des exemples réels de groupes APT, des procédures de détection et des contre-mesures. Tout scénario d'attaque comporte un sous-ensemble de ces 14 tactiques.

Tactique MITRE	Description
T1 — Reconnaissance	Collecte d'informations sur la cible : OSINT, DNS, réseaux sociaux, LinkedIn, sites web. Identifiants des employés, architecture technique. Technique typique : T1592 (collecte d'informations sur les machines du système).
T2 — Développement de ressources	Création, achat ou compromission de ressources : domaines, comptes, certificats, infrastructure C2. Technique typique : T1586 (compromission de comptes existants).
T3 — Accès initial	Point d'entrée dans le réseau : phishing, exploitation de serveurs web publics, compromission de la supply chain. Technique typique : T1566 (hameçonnage).

Tactique MITRE	Description
T4 — Exécution	Exécution du code de l'attaquant : scripts PowerShell, macros Office, interpréteurs de commandes. Technique typique : T1059 (utilisation d'un interpréteur de commandes).
T5 — Persistance	Maintien de l'accès malgré les redémarrages : modification du registre, création de services, scripts de démarrage. Technique typique : T1098 (manipulation de compte).
T6 — Élévation de privilèges	Obtention de droits supérieurs : exploitation de vulnérabilités locales, abus de mécanismes de contrôle des privilèges. Technique typique : T1548 (abus des mécanismes de contrôle).
T7 — Furtivité	Évitement de la détection : désactivation des antivirus, chiffrement du malware, utilisation de processus légitimes. Technique typique : T1484 (modification des politiques Active Directory).
T8 — Accès aux credentials	Vol d'identifiants : keylogging, extraction de mémoire, attaques sur Active Directory (Kerberoasting, Pass-the-Hash). Technique typique : T1110 (brute-forcing).
T9 — Découverte	Cartographie de l'environnement : comptes, machines, réseaux, partages. Utilisation des outils natifs de l'OS pour rester furtif. Technique typique : T1087 (découverte des comptes).
T10 — Mouvement latéral	Extension de la compromission : exploitation de services distants, réutilisation de credentials. Technique typique : T1210 (exploitation de services distants).
T11 — Collecte	Rassemblement des données cibles : fichiers, screenshots, captures audio/vidéo. Technique typique : T1123 (capture de flux audio).
T12 — C2 (Commande & Contrôle)	Communication avec les systèmes compromis : protocoles courants détournés (DNS, HTTP, messagerie) pour éviter la détection. Technique typique : T1071 (utilisation de protocoles réseau standard).
T13 — Exfiltration	Vol des données : compression, chiffrement, canaux alternatifs. Technique typique : T1020 (exfiltration automatisée).
T14 — Impact	Action finale : chiffrement (ransomware), destruction, falsification de données, sabotage. Technique typique : T1486 (chiffrement de données).

4.3.4 Attaques de déni de service (DoS/DDoS)

L'objectif de l'attaquant est de saturer les ressources du système pour attenter à la disponibilité : bande passante réseau, capacité d'un serveur, espace d'adressage d'un DHCP. La puissance d'une attaque DoS se mesure en débit (bits/s ou requêtes/s).

Le mécanisme d'amplification par réflexion est particulièrement redoutable : une requête DNS de quelques dizaines d'octets peut générer une réponse de milliers d'octets (facteur d'amplification DNS : 179), redirigée vers la cible victime via une requête avec adresse source falsifiée (IP spoofing). Combiné à un botnet (des milliers de machines infectées générant simultanément des requêtes), les débits peuvent atteindre des niveaux extrêmes : NTP (UDP 123) — facteur 556 — peut générer jusqu'à 400 Gbps ; Memcached (UDP 11211) — facteur 51 200 — a généré 1,6 Tbps lors de l'attaque contre OVH en 2018. L'attaque DDoS sur Google Cloud en 2023 a atteint 398 millions de requêtes par seconde.

Les protocoles utilisés pour l'amplification (DNS, NTP, CLDAP, Memcached) ne peuvent pas être filtrés sur la seule base de leur port car ils sont indispensables au bon fonctionnement des systèmes. La contre-mesure principale est le scrubbing (déviation du trafic vers des centres spécialisés qui filtrent le trafic malveillant) — services offerts par Cloudflare, Akamai, AWS Shield.

4.3.5 Le malware — Taxonomie et évolution

Le terme malware (malicious software) désigne un logiciel ou un code malveillant. Il est très général et ne précise pas le mode d'action. Les malwares modernes sont conçus pour être résidents (actifs en mémoire en permanence), furtifs (à l'insu de l'utilisateur), et persistants (capables de se relancer après extinction).

Type de malware	Description
Virus	Code malveillant auto-reproducteur qui nécessite l'action d'un utilisateur pour se propager (frappe au clavier, ouverture d'un fichier). Capable d'être furtif et de muter.
Ver (Worm)	Réside en mémoire RAM et se propage de façon autonome via les canaux de communication. Ne nécessite pas l'action de l'utilisateur après introduction. WannaCry, NotPetya étaient des vers.
Cheval de Troie (Trojan)	Fonctionne en mode client (extérieur) et serveur (introduit dans le système). Apparaît légitime mais réalise des actions malveillantes en arrière-plan. Base de nombreux RATs (Remote Access Trojans).
Rootkit	Malware conçu pour infecter une machine et installer une boîte à outils : enregistrement des frappes clavier, capture de mots de passe, communication avec l'extérieur. Conçu pour se faire passer pour un logiciel légitime.
Ransomware	Chiffre les données ou le système pour les rendre indisponibles, puis exige une rançon. Double extorsion : chiffrement + menace de publication. Architecture complexe (C2, paiement, négociation, support).
APT malware	Conçu pour fonctionner dans la durée (semaines, mois, années) de manière furtive, souvent pour l'exfiltration de données. Détection difficile, nécessite des algorithmes de traitement des signaux faibles.
Bombe logique	Attend un événement pour s'exécuter : date, action, valeur de donnée. Peut être implantée longtemps à l'avance (menace interne) pour s'activer lors d'un licenciement par exemple.

Type de malware	Description
Stuxnet (cas d'école)	Malware étatique (USA/Israël, 2010) conçu pour détruire les centrifugeuses d'enrichissement d'uranium de Natanz (Iran). Implémentait 12 des 14 tactiques MITRE (sauf T13 exfiltration). Considéré comme le premier cyber-armement à impact physique documenté.

4.4 Caractérisation du système — Ce qu'il faut protéger

La question « qu'est-ce qu'il faut protéger ? » est la première à laquelle doit répondre tout responsable de la sécurité. La réponse passe par la notion d'actifs et la connaissance des vulnérabilités du système.

4.4.1 Les actifs — Le capital à protéger

Les actifs désignent ce qu'il faut protéger. Dans le domaine de l'intelligence économique, les données constituent le capital informationnel — la partie formalisée d'un capital immatériel plus large incluant les savoirs-faire, les brevets, la réputation, les relations clients. L'actif principal à protéger n'est donc pas le système informatique en lui-même, mais les processus métier qu'il supporte et les données qu'il héberge.

La cartographie des actifs — recenser toutes les données, applications, systèmes, et processus de valeur — est la première étape indispensable de toute démarche de sécurité. Cette cartographie doit être maintenue à jour : dans des organisations qui évoluent vite (nouvelles applications, nouvelles interconnexions, nouvelles acquisitions), une cartographie obsolète est une source de risques non adressés.

4.4.2 Vulnérabilités, failles et exploits

Les vulnérabilités caractérisent un périmètre fonctionnel non sécurisé, donc exploitable par la malveillance. Elles existent à trois niveaux :

- Organisationnelles : absence de politique de sécurité, absence de classification des données, pas de politique de sauvegarde, pas de procédure d'offboarding des collaborateurs
- Humaines : faibles compétences numériques des utilisateurs, pas de sensibilisation aux risques, compréhension insuffisante des menaces
- Techniques : logiciels non mis à jour, versions hétérogènes, mauvaise configuration des applications, ports ouverts inutilement, credentials par défaut

La distinction faille / vulnérabilité : une faille a un sens plus spécifiquement technique (on ne parle jamais de « faille humaine »). Une faille 0-day désigne une vulnérabilité non connue de l'éditeur du logiciel — et donc non corrigée — qui peut être exploitée immédiatement si découverte par un attaquant. Sa valeur sur les marchés cybercriminels est très élevée (jusqu'à plusieurs millions de dollars pour une 0-day dans un système très répandu).

Un exploit (code d'exploitation) est un composant logiciel capable d'exploiter une vulnérabilité ou faille de sécurité, localement ou via un réseau. Toute CVE (Common Vulnerabilities and Exposures, gérée par MITRE) publiée sans que les systèmes concernés aient été mis à jour est potentiellement exploitable. Le délai entre la publication d'une CVE critique et son exploitation active est désormais mesuré en heures (Log4Shell : premières exploitations 2h après la publication).

Terme technique	Description
CVE (Common Vulnerabilities and Exposures)	Identifiant unique d'une vulnérabilité publiée. Format : CVE-ANNÉE-NUMÉRO. Exemple : CVE-2021-44228 = Log4Shell. Géré par MITRE. Base NVD (National Vulnerability Database) du NIST maintient les scores CVSS.
CVSS (Common Vulnerability Scoring System)	Score de 0 à 10 évaluant la criticité d'une CVE selon son exploitabilité et son impact. CVSS < 4 : bas ; 4-7 : moyen ; 7-9 : haut ; 9-10 : critique. Log4Shell : CVSS 10.0 (maximum).
Faille 0-day	Vulnérabilité non connue de l'éditeur, sans correctif disponible. Exploitable immédiatement. Valeur marchande très élevée sur le marché des vulnérabilités (légal via bug bounty, illégal via Darknet).
Proof of Concept (PoC)	Démonstration fonctionnelle qu'une vulnérabilité est exploitable. La publication d'un PoC accélère massivement l'exploitation par des attaquants moins qualifiés (script kiddies).
Patch (correctif)	Mise à jour logicielle corrigeant une ou plusieurs vulnérabilités. Le délai entre la publication d'un patch et son déploiement sur les systèmes de production est la fenêtre d'exposition. Politique de patch management indispensable.
Analyse de vulnérabilités	Audit statique (scanners automatisés : Nessus, OpenVAS, Qualys) ou dynamique (tests d'intrusion). Caractère non exhaustif : deux prestataires différents génèreront des rapports différents.

4.4.3 Protection et détection

La protection est le premier mot-clé de la SSI. Elle couvre trois dimensions. La dimension technique concerne le système informatique dans son ensemble (infrastructure, réseau, machines, applications). La dimension organisationnelle englobe la politique de sécurité (PSSI), le SMSI (Système de Management de la Sécurité de l'Information), les méthodes préventives (plans de secours, politique de sauvegarde) et curatives (gestion des incidents). La dimension juridique concerne les obligations légales : toutes les organisations sont concernées au minimum par la protection des données personnelles (RGPD).

La détection — identifier les symptômes appelés Indicateurs de Compromission (IOC) — peut se faire à plusieurs niveaux : par l'utilisateur lui-même (affichage perturbé, données indisponibles), par le système de supervision (augmentation anormale du trafic, tentatives de connexion infructueuses), par des sondes IDS (Intrusion Detection System) / IPS (Intrusion Prevention System). Les IDS alertent, les IPS bloquent. Les alertes seules ne suffisent pas : p5 ne se réduit que si elles sont traitées rapidement et efficacement.

4.4.4 L'impact — La phase T14 du scénario d'attaque

L'impact désigne le niveau de dommage causé par l'attaque. Il correspond à la phase T14 (Impact) de la matrice MITRE. Les formes d'impact incluent : la destruction ou corruption de données, le chiffrement des données (ransomware), la mise hors service de serveurs ou d'applications, la perturbation des processus métier, les dommages matériels (systèmes cyber-physiques), et les dommages aux personnes (sécurité physique, soins médicaux).

Réduire l'impact (p5) dépend principalement de la qualité de la réponse aux incidents et de l'existence de sauvegardes testées. Un système de sauvegarde testé régulièrement (règle 3-2-1 : 3 copies, 2 supports différents, 1 hors site — et idéalement 1 offline pour résister au ransomware) permet de limiter l'impact d'un ransomware à une interruption temporaire plutôt qu'à une perte définitive de données.

4.5 La gestion des risques — Du diagnostic au plan d'action

La gestion des risques est le processus structuré qui permet de passer de l'identification des vulnérabilités à un plan d'action priorisé et cohérent. Elle se décompose en quatre phases.

4.5.1 P1 — Identification

L'identification repose sur trois piliers : l'analyse de la menace (qui peut nous en vouloir, pourquoi, quels sont ses modes d'action — Threat Intelligence), l'analyse de vulnérabilités (audit, tests d'intrusion, scan automatisé), et l'identification des scénarios redoutés (quels événements pourraient impacter quels actifs ?).

Pour les PME et TPE, la perception du risque est souvent réduite au minimum, avec des croyances erronées : « je suis trop petit, je n'intéresse personne » (faux : les PME sont ciblées précisément car moins bien protégées), « ça n'arrive qu'aux autres » (faux : 60 % des cyberattaques ciblent des entreprises de moins de 1 000 employés selon le DBIR 2024), « nous ne sommes pas concernés » (faux : toutes les organisations qui traitent des données personnelles ou dépendent d'un SI sont concernées).

4.5.2 P2 — Estimation

Le terme p (vraisemblance) est évalué qualitativement selon une échelle de 1 à 4 : peu probable (1), assez probable (2), probable (3), très probable (4). Il se décompose en 5 facteurs probabilistes (p1 à p5) comme vu précédemment. Les termes p1 et p2 sont quasi-constants (proche de 1 — les attaquants existent et passent à l'acte). Le rôle de la SSI est de réduire p3, p4 et p5.

Le terme D (impact) est estimé qualitativement selon une échelle analogue : peu grave (1), assez grave (2), grave (3), très grave (4). Il prend en compte : la valeur des actifs menacés, l'impact opérationnel (durée d'interruption, processus bloqués), l'impact réglementaire (amendes RGPD/NIS2), l'impact réputationnel (perte de clients, couverture médiatique).

4.5.3 P3 — Évaluation et seuil d'acceptabilité

Le risque R = p × D est calculé pour chaque scénario identifié. Représentés dans un graphe p × D, les risques sont visualisés par un code couleur : rouge (p élevé et D élevé — traitement prioritaire), orange (l'un des deux est élevé), jaune (p et D modérés), vert (p et D faibles — risque résiduel acceptable). Un seuil d'acceptabilité est fixé : tous les risques au-dessus de ce seuil doivent être traités.

La fixation du seuil fait intervenir trois perspectives : technique (jugement des experts cybersécurité sur le niveau de protection atteignable), économique (la balance coût/bénéfices — les investissements de sécurité doivent être proportionnés aux risques couverts), et sociale/organisationnelle (la sécurité peut être vécue comme une contrainte — limitation d'accès, allongement des procédures, frein aux projets — et sa perception varie selon les acteurs).

4.5.4 P4 — Traitement

Quatre options de traitement existent pour chaque risque identifié au-dessus du seuil :

- Réduction : mise en place de mesures de protection et de détection qui réduisent p ou D (patch management, segmentation réseau, sauvegardes, formation)

- Transfert : assurance cyber — transférer financièrement tout ou partie du risque vers un assureur
- Acceptation : pour les risques résiduels (sous le seuil d'acceptabilité) — le risque est identifié, documenté et assumé
- Évitement : supprimer l'activité qui génère le risque — par exemple, décider de ne pas exposer un système critique directement sur Internet

4.5.5 Méthodes de gestion des risques — EBIOS RM, MEHARI, ISO 27005

Méthode / Norme	Description
EBIOS Risk Manager (ANSSI)	Méthode française officielle développée par l'ANSSI. 5 ateliers : cadrage + socle, sources de risques, scénarios stratégiques, scénarios opérationnels, traitement. Référence pour les OIV/OSE et les organisations soumises à NIS2. Compatible ISO 27001/27005.
MEHARI (CLUSIF)	Méthode de gestion des risques développée par le CLUSIF. Appréciée pour sa simplicité. Dernière version : 2010. Moins utilisée aujourd'hui au profit d'EBIOS RM.
ISO 27005	Norme internationale fournissant un cadre de gestion du risque lié à la sécurité de l'information. Conseils sur l'appréciation, le traitement, l'acceptation du risque. S'appuie sur l'ISO 27002 (contrôles de sécurité) comme référentiel.
ISO 27002	Norme de référence listant 93 mesures de sécurité organisées en 4 thèmes : organisationnelles (37), personnes (8), physiques (14), technologiques (34). Sert de cadre référentiel aux audits de sécurité.
NIST Cybersecurity Framework 2.0	Cadre américain en 6 fonctions (Govern, Identify, Protect, Detect, Respond, Recover). Non certifiable mais très flexible. Langage commun entre équipes techniques et direction.
CIS Controls v8	18 contrôles prioritaires définis par le Center for Internet Security. Hiérarchisés en 3 groupes de mise en œuvre (IG1 pour les petites structures jusqu'à IG3 pour les grandes). Pragmatique et accessible.

4.6 La réponse à incident — Gérer la crise

La gestion des incidents est le processus qui permet de minimiser les dommages quand une attaque se produit malgré les protections en place. La réponse à incident n'est pas une activité ponctuelle — c'est un processus continu, préparé bien avant tout incident, entraîné régulièrement, et amélioré après chaque crise.

4.6.1 Définitions — Événement, incident, crise

Un événement est quelque chose d'observable sur le réseau ou le système : connexion à un espace partagé, réception d'une requête, envoi d'un email, blocage d'une tentative de connexion par le pare-feu. Les événements génèrent des traces (logs) qui renseignent sur le type d'événement, le lieu, la date et l'heure. La volumétrie des logs dans un système d'entreprise est considérable — de l'ordre de plusieurs gigaoctets par jour, justifiant l'usage d'un SIEM.

Un incident est un événement aux effets négatifs : crash système, inondation d'un serveur par des requêtes, utilisation abusive de privilèges, accès non autorisé à des données sensibles, exécution d'un malware. Une crise est un incident hors norme par son ampleur (milliers de machines compromises), sa nouveauté (type d'attaque inconnue), ou son caractère incontrôlable (propagation non maîtrisée). WannaCry et NotPetya en 2017 constituent des exemples de crises : des dizaines de milliers de machines compromises dans le monde entier, des milliers d'experts mobilisés pendant plusieurs semaines.

Niveau de sévérité des incidents (ISO 27035)	Description
Niveau 2 — Haute sévérité	Dommages significatifs. Exemples : intrusion réseau, compromission physique du SI, perte d'informations ultra-confidentielles non chiffrées, infection de plus de 25 % des machines, hameçonnage en cours utilisant le nom de domaine.
Niveau 1 — Sévérité moyenne	Dommages sans mettre le système global en danger. Exemples : attaque DoS, utilisation d'accès non autorisés, intrusion automatisée, infection par malware, modification suspecte d'activité.
Niveau 0 — Basse sévérité	Faible impact. Exemples : violation de procédure détectée dans les logs, perte ou vol de portable contenant des données non classifiées, installation d'un logiciel non autorisé. Ne veut pas dire qu'on ne le traite pas.

4.6.2 La procédure de réponse à incident

La réponse à incident (IR) suit le cycle NIST SP 800-61 en 4 phases + REX :

1. PRÉPARATION : Constitution et formation de l'équipe CSIRT/CERT, rédaction et validation du Plan de Réponse aux Incidents (PRI), déploiement des outils de détection et forensiques (SIEM, EDR, outils d'acquisition), exercices de simulation (tabletop exercises). C'est la phase la plus critique — sans plan testé, la gestion d'un incident réel sera chaotique.
2. DÉTECTION ET ANALYSE : Qualification des alertes (vrai incident ou faux positif ?), classification par type et sévérité (P1-P4), documentation initiale dans le ticket d'incident (timeline des événements, systèmes impliqués). Le SIEM et l'EDR sont les outils centraux de cette phase.
3. CONFINEMENT, ÉRADICATION ET RÉTABLISSEMENT : Isolation réseau des systèmes compromis (décision difficile si systèmes critiques — à anticiper dans le PRI), éradication du malware et fermeture des accès de l'attaquant, restauration depuis des sauvegardes saines vérifiées (ne jamais restaurer sans s'être assuré que la sauvegarde n'est pas elle-même compromise).
4. POST-INCIDENT ET REX : Communication réglementaire (CNIL en 72h si données personnelles, ANSSI si OIV/OSE, clients selon les obligations contractuelles), Retour d'EXpérience documenté (timeline complète, analyse des causes racines, plan d'amélioration concret). Un incident sans REX est une opportunité d'apprentissage gaspillée.

4.6.3 Le SIEM — Système nerveux central de la détection

Le SIEM (Security Information and Event Management) centralise, normalise et corrèle les événements de sécurité de l'ensemble du SI. Un événement isolé (5 échecs de connexion SSH) peut être anodin. Mais la corrélation avec d'autres événements (connexion réussie 5 minutes plus tard depuis une IP différente, suivi d'une création d'un nouveau compte admin) révèle une séquence d'attaque. Les règles de corrélation du SIEM — calquées sur les TTPs MITRE ATT&CK — sont au cœur de sa valeur.

Les solutions leaders : Splunk Enterprise Security (référence de facto), Microsoft Sentinel (cloud-native Azure), IBM QRadar (fort sur la corrélation), Elastic SIEM (open source). Le SOAR (Security Orchestration, Automation and Response) est le multiplicateur de force : il automatise les réponses répétitives (enrichissement d'alertes, blocage d'IP, isolation d'endpoint), libérant les analystes pour les investigations complexes.

4.6.4 CERT, CSIRT et SOC — Les équipes de réponse

Structure de réponse	Description
CERT (Computer Emergency Response Team)	Équipe spécialisée dans la réponse aux incidents et la coordination. CERT-FR (ANSSI) : remontée des incidents des administrations et OIV, publication d'alertes et bulletins de sécurité. Créé en 1990 aux USA (CERT/CC à Carnegie Mellon).
CSIRT (Computer Security Incident Response Team)	Terme générique pour les équipes de réponse aux incidents. Peut être interne à une organisation (CSIRT d'entreprise) ou sectoriel (CSIRT-Santé en France). Le réseau des CSIRT européens est coordonné par ENISA.
SOC (Security Operations Center)	Centre opérationnel de surveillance 24/7 du SI, de détection et de réponse aux incidents. Trois niveaux : L1 (surveillance et triage), L2 (investigation approfondie), L3 (threat hunting, réponse aux incidents majeurs). Peut être internalisé ou externalisé (MSSP).
Différence CERT vs SOC	Le SOC est orienté sur la détection et la réponse en temps réel (opérationnel). Le CERT est orienté sur la gestion des incidents complexes, la forensique, et la coordination (expertise). Dans les grandes organisations, les deux coexistent.

4.7 Autres définitions importantes

La cybersécurité englobe trois grands domaines non-disjoints selon la définition de l'ANSSI :

- La sécurité des systèmes d'information (SSI) : toutes les actions pour défendre le SI contre les menaces internes et externes. Mots-clés : protection et détection.
- La lutte contre la cybercriminalité : actions pour étudier la malveillance sous toutes ses formes, établie par rapport au droit pénal. Mot-clé : recherche de preuves numériques (digital forensic). Rôle des officiers de police judiciaire, magistrats, avocats spécialisés.
- La cyberdéfense : SSI appliquée aux organismes d'importance vitale. Caractérisée par des exigences de résilience (continuer en mode dégradé), de sécurité globale (éviter les effets domino cyber → physique), et de résilience de systèmes de systèmes.

Sur la cyber-guerre : en matière de droit international, le terme n'a pas de valeur juridique — personne n'a jamais déclaré de cyber-guerre. Toutes les actions visant les SI d'un État étranger relèvent du droit pénal. L'attaque massive contre l'Estonie en 2007 (déni de service contre les serveurs publics pendant plusieurs jours) par son puissant voisin russe, réalisée via des groupes de cyber-criminels nationalistes pour permettre au commanditaire de nier sa responsabilité, illustre le modèle de la guerre hybride cyber.

CHAPITRE 5 — SÉCURITÉ DES RÉSEAUX ET DES INFRASTRUCTURES

5.1 Architecture réseau sécurisée

5.1.1 Modèle OSI et points d'intervention

Le modèle OSI (Open Systems Interconnection) en 7 couches fournit un cadre de référence pour analyser les menaces et les contrôles de sécurité à chaque niveau. Chaque couche présente des vulnérabilités spécifiques et des mécanismes de protection appropriés : les attaques physiques (couche 1), l'interception et l'injection sur les trames Ethernet (couche 2 — ARP spoofing, VLAN hopping), le spoofing d'adresses IP (couche 3), les attaques de protocoles de transport (couche 4 — TCP SYN flood), et les attaques applicatives (couche 7 — HTTP floods, injection, XSS).

La défense en profondeur réseau applique ce principe aux couches réseau : protection périmétrique (couches 3-4 avec les firewalls classiques), inspection approfondie (couches 3-7 avec les NGFW), détection d'anomalies comportementales (couche 7 et analytics), et protection contre les attaques applicatives (WAF — Web Application Firewall). La segmentation réseau crée des zones de confiance distinctes avec des politiques de filtrage inter-zones.

5.1.2 Zones de sécurité et DMZ

La segmentation réseau divise le réseau en zones de confiance distinctes, limitant la propagation latérale d'un attaquant ayant compromis un segment. L'architecture classique distingue : Internet (zone non fiable), la DMZ (zone démilitarisée — héberge les services exposés à Internet : serveurs web, serveurs mail, proxys), le réseau interne (zone de confiance modérée), la zone serveurs (protection renforcée), et la zone d'administration (accès très restreint aux équipes IT).

Les VLAN (Virtual Local Area Network) permettent la segmentation logique à la couche 2, séparant les flux de différents départements ou niveaux de sensibilité sur la même infrastructure physique. La micro-segmentation, concept central du Zero Trust, pousse la granularité jusqu'au niveau de la charge de travail individuelle (workload), implémentée par des solutions comme VMware NSX, Illumio, ou les security groups des plateformes cloud (AWS, Azure, GCP).

5.2 Firewalls et Systèmes de Prévention d'Intrusion

4.2.1 Évolution des firewalls

Les firewalls (pare-feu) constituent la première ligne de défense périmétrique. Leur évolution reflète celle des menaces : les firewalls de première génération (années 1980-1990) filtraient le trafic selon les adresses IP et les ports (filtrage de paquets stateless) ; les firewalls stateful (années 1990-2000) maintenaient l'état des connexions pour des décisions de filtrage plus précises ; les firewalls applicatifs (proxy firewalls) inspectaient le contenu des protocoles applicatifs ; et les NGFW (Next-Generation Firewalls, Palo Alto Networks, Fortinet, Check Point, Cisco) intègrent aujourd'hui l'inspection SSL/TLS, l'identification des applications (App-ID), l'identification des utilisateurs (User-ID), la prévention d'intrusion (IPS), et les flux de threat intelligence.

La configuration d'un firewall doit suivre le principe de moindre accès : la règle par défaut est le refus (deny all), et l'on autorise explicitement uniquement le trafic légitime nécessaire. Les règles doivent être documentées, régulièrement auditées (nettoyage des règles obsolètes), et testées. Une politique de firewall est un document vivant qui doit évoluer avec les besoins métier.

5.2.2 IDS et IPS

Les systèmes de détection d'intrusion (IDS — Intrusion Detection Systems) et de prévention d'intrusion (IPS — Intrusion Prevention Systems) analysent le trafic réseau à la recherche

d'indicateurs d'attaque. L'IDS génère des alertes ; l'IPS peut bloquer activement le trafic suspect. Ils opèrent selon deux approches complémentaires : la détection par signatures (comparaison du trafic à une base de signatures d'attaques connues — efficace mais aveugle aux attaques nouvelles) et la détection par anomalies (modélisation du comportement normal pour détecter les déviations — capable de détecter les attaques inconnues mais génère plus de faux positifs).

Snort (open source, créé par Martin Roesch en 1998) et Suricata (open source, IDS/IPS/NSM — Network Security Monitoring) sont les outils de référence. Les solutions commerciales incluent les offres intégrées dans les NGFW (Palo Alto Threat Prevention, Fortinet IPS) et les solutions dédiées (Cisco Firepower, Trend Micro TippingPoint). Le Network Detection and Response (NDR) représente l'évolution vers des capacités analytiques avancées : modèles ML pour la détection d'anomalies comportementales, corrélation avec d'autres sources de données.

5.3 VPN et accès distant sécurisé

Les réseaux privés virtuels (VPN — Virtual Private Networks) créent des tunnels chiffrés permettant l'accès sécurisé aux ressources d'une organisation depuis n'importe quelle localisation. La pandémie de COVID-19 a provoqué une généralisation du télétravail qui a mis sous pression les architectures VPN traditionnelles et accéléré la transition vers le Zero Trust Network Access (ZTNA).

OpenVPN (SSL/TLS) et IPSec/IKEv2 sont les technologies VPN les plus répandues en entreprise. WireGuard, plus récent, gagne rapidement du terrain grâce à ses performances supérieures et sa simplicité. Les VPN SSL/TLS clientless permettent l'accès via navigateur web sans client dédié, réduisant les contraintes de déploiement. Les principales considérations de sécurité pour les VPN incluent la gestion des certificats clients, l'authentification MFA obligatoire, le split tunneling (à éviter pour les accès sensibles car contourne la surveillance), et la mise à jour régulière des logiciels VPN (plusieurs vulnérabilités critiques ont affecté Pulse Secure, Citrix, Fortinet en 2019-2023).

Le ZTNA (Zero Trust Network Access) remplace progressivement le VPN en adoptant une approche granulaire : plutôt que d'accorder un accès réseau complet, le ZTNA autorise l'accès à des applications spécifiques, en fonction du contexte (identité de l'utilisateur, posture du device, localisation, comportement). Les solutions principales incluent Zscaler Private Access (ZPA), Cloudflare Access, Palo Alto Prisma Access, et les solutions Microsoft (Azure AD Application Proxy).

5.4 SIEM et Security Operations Center

4.4.1 SIEM — Security Information and Event Management

Un SIEM centralise, normalise et corrèle les événements de sécurité générés par les équipements du SI (serveurs, firewalls, IDS, applications, proxies, bases de données, annuaires). Son objectif est de fournir une visibilité unifiée sur la posture de sécurité, de détecter les incidents par corrélation d'événements disparates, et de faciliter les investigations forensiques. La formule classique est SIEM = SIM (gestion des informations de sécurité) + SEM (gestion des événements de sécurité).

Les fonctionnalités essentielles d'un SIEM moderne incluent la collecte multi-sources (syslog, API, agents, fichiers), la normalisation (Common Event Format — CEF, LEEF), le stockage à long terme avec indexation rapide, les règles de corrélation et de détection (alertes sur des patterns d'événements), les tableaux de bord et rapports de conformité, et l'intégration avec les outils de réponse aux incidents (SOAR). Les solutions leaders incluent Splunk Enterprise Security, IBM QRadar, Microsoft Sentinel (cloud-native), Elastic SIEM (open source), et LogRhythm.

4.4.2 SOC — Security Operations Center

Le Security Operations Center (SOC) est l'équipe et l'infrastructure organisés pour surveiller en permanence le SI, détecter et analyser les incidents de sécurité, et coordonner la réponse. Un SOC mature opère selon trois niveaux : le niveau 1 (analystes L1) assure la surveillance continue, le triage des alertes et l'escalade des incidents nécessitant une investigation approfondie ; le niveau 2 (analystes L2) conduit les investigations approfondies, effectue la corrélation d'événements et coordonne la réponse initiale ; le niveau 3 (analystes L3 / threat hunters / architectes) assure la réponse aux incidents majeurs, le développement des règles de détection, le threat hunting proactif et l'amélioration continue des capacités.

L'automatisation et l'orchestration — SOAR (Security Orchestration, Automation and Response) — permettent d'automatiser les réponses aux incidents répétitifs (enrichissement d'alertes, blocage d'IP, isolation de machines), libérant les analystes pour les tâches à haute valeur ajoutée. Les plateformes SOAR majeures incluent Palo Alto XSOAR (anciennement Demisto), Splunk SOAR, IBM Resilient, et TheHive/Cortex (open source).

5.5 Sécurité Wi-Fi et mobilité

La sécurité des réseaux sans fil (Wi-Fi) représente un défi particulier du fait de la propagation physique du signal radio, potentiellement captable en dehors des locaux. Le protocole WEP (Wired Equivalent Privacy, 1997) était cryptographiquement cassé dès 2001 ; WPA (Wi-Fi Protected Access, 2003) a été une correction temporaire ; WPA2 (2004, basé sur AES-CCMP) reste acceptable mais présente des vulnérabilités (KRACK attack, PMKID attack permettant des attaques hors ligne sur les mots de passe) ; WPA3 (2018) corrige ces failles avec SAE (Simultaneous Authentication of Equals, remplaçant PSK) et le Perfect Forward Secrecy.

Les bonnes pratiques pour la sécurité Wi-Fi d'entreprise incluent l'utilisation de WPA2/WPA3 Enterprise (authentification 802.1X avec serveur RADIUS et certificats individuels, éliminant le risque de partage de clé), la séparation du réseau invité (SSID dédié avec isolation et filtrage des accès), la détection des points d'accès non autorisés (rogue AP detection), et la surveillance du spectre Wi-Fi (Wireless IDS/IPS).

5.6 Sécurité des protocoles DNS et BGP

Le DNS (Domain Name System) est une infrastructure critique d'Internet particulièrement ciblée par les attaquants : empoisonnement du cache DNS (DNS cache poisoning), attaques DNS amplification (utilisées dans les DDoS massifs), tunneling DNS (exfiltration de données cachée dans des requêtes DNS apparemment légitimes), et typosquatting (enregistrement de domaines similaires pour le phishing). DNSSEC (DNS Security Extensions) apporte la signature cryptographique des enregistrements DNS, mais son déploiement reste partiel. DNS over HTTPS (DoH) et DNS over TLS (DoT) chiffrent les requêtes DNS pour protéger la confidentialité.

BGP (Border Gateway Protocol), le protocole de routage inter-domaines d'Internet, est structurellement vulnérable aux hijacking : un routeur BGP peut annoncer des préfixes IP qu'il ne devrait pas, redirigeant le trafic vers un AS (Autonomous System) contrôlé par l'attaquant. Le BGP hijacking de plusieurs opérateurs majeurs a provoqué des pannes et interceptions de trafic. RPKI (Resource Public Key Infrastructure) permet la validation cryptographique des annonces BGP (Route Origin Validation — ROV) et est en déploiement progressif chez les grands opérateurs.

CHAPITRE 6 — SÉCURITÉ APPLICATIVE ET DEVSECOPS

INTRODUCTION

75 % des attaques visent aujourd'hui la couche applicative (Gartner). Les applications — web, mobiles, API, microservices — sont la cible principale des attaquants car elles constituent l'interface directe entre le système d'information et le monde extérieur. La sécurité applicative ne peut pas être un afterthought : elle doit être intégrée dès la conception.

Ce chapitre présente le paradigme DevSecOps (intégration de la sécurité dans les pipelines CI/CD), la modélisation des menaces (STRIDE), les outils d'analyse (SAST, DAST, IAST), les tests de pénétration applicatifs, la sécurité des API (vecteur en forte croissance), et la sécurité des conteneurs et de l'Infrastructure as Code.

OBJECTIFS PÉDAGOGIQUES

- ✓ Comprendre et appliquer le paradigme DevSecOps dans un pipeline CI/CD
- ✓ Mettre en œuvre la modélisation des menaces avec la méthode STRIDE
- ✓ Distinguer SAST, DAST et IAST et les utiliser dans les pipelines
- ✓ Conduire un test de pénétration applicatif selon les méthodologies PTES/OWASP
- ✓ Identifier et mitiger les vulnérabilités de l'OWASP API Security Top 10 2023
- ✓ Appliquer les bonnes pratiques de sécurité des conteneurs et de l'IaC

6.1 Le paradigme DevSecOps — La sécurité comme culture

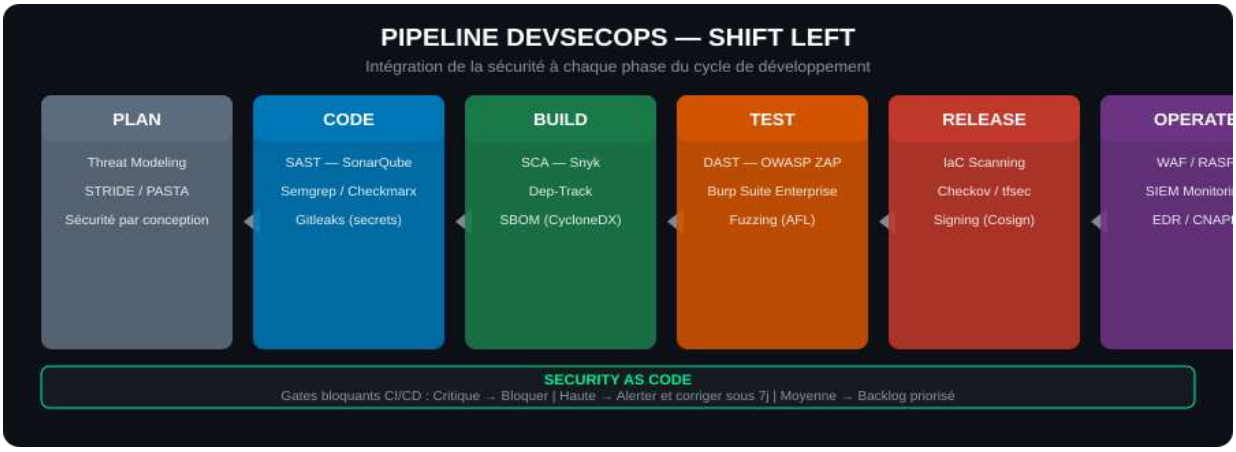

Figure 6 — Pipeline DevSecOps : Intégration de la sécurité à chaque phase CI/CD

DevSecOps est une culture, pas un outil. L'objectif est de rompre avec le modèle traditionnel dans lequel la sécurité est une étape finale perçue comme un obstacle. La donnée clé : corriger une vulnérabilité en phase de conception coûte 100× moins qu'en production (NIST SP 800-64). Les quatre piliers : Security as Code (contrôles codés et versionnés), responsabilité partagée (chaque développeur est co-responsable), remédiation rapide (vulnérabilités traitées comme des bugs avec SLA : P0 en 24h), et mesure continue (MTTD/MTTR visibles de tous).

Phase CI/CD	Description
Planification	Threat modeling (STRIDE, PASTA) — Analyse des risques — Politique de gestion des secrets
Développement (Code)	SAST : SonarQube, Semgrep, Checkmarx, CodeQL — Pre-commit hooks (detect-secrets, gitleaks)
Build	SCA : Snyk, OWASP Dependency-Track — Scan images Docker (Trivy, Grype) — Génération SBOM
Test	DAST : OWASP ZAP, Burp Suite Enterprise — Fuzzing (AFL, LibFuzzer)
Release/Deploy	IaC scanning : Checkov, tfsec, kube-score — Signature des artefacts (Cosign/Sigstore)
Operate/Monitor	RASP — WAF — Surveillance des logs applicatifs — Alertes SIEM
Gestion des secrets	HashiCorp Vault, AWS Secrets Manager, Azure Key Vault — Rotation automatique

6.2 Tests de pénétration et OWASP API Top 10

Un pentest est une attaque simulée et autorisée (autorisation écrite obligatoire — Rules of Engagement). Types : black box (aucune info), white box (code source + architecture), grey box (information partielle). Méthodologie PTES : 7 phases de pre-engagement à reporting. La distribution Kali Linux intègre 600+ outils : Nmap, Metasploit, Burp Suite, sqlmap, hashcat, BloodHound, Impacket.

Risque API OWASP 2023	Description
API1 — Broken Object Level Auth.	IDOR via manipulation d'IDs. GET /api/orders/1234 retourne les données d'un autre utilisateur.
API2 — Broken Authentication	Authentification absente ou insuffisante. Tokens sans expiration, clés API en clair dans les URLs.
API4 — Unrestricted Resource Consumption	Absence de rate limiting. DoS applicatif, scraping massif, abus de ressources.
API7 — SSRF	Server-Side Request Forgery via paramètres URL — requêtes vers des ressources internes.
API8 — Security Misconfiguration	CORS permissifs, headers absents, messages d'erreur verbeux exposant la stack.
API9 — Improper Inventory Management	Shadow APIs — versions obsolètes ou non documentées accessibles.

3.3 Sécurité des conteneurs et de l'IaC

Sécurité des images : scan Trivy/Grype, images base minimales (Distroless, Alpine), signature Sigstore/Cosign. Sécurité Kubernetes : RBAC strict, Network Policies inter-pods, Pod Security Standards, audit logging. IaC scanning : Checkov, tfsec, kube-score — gates bloquants dans les pipelines CI/CD.

CHAPITRE 7 — GOUVERNANCE, RISQUE ET CONFORMITÉ

INTRODUCTION
La gouvernance de la cybersécurité est le cadre organisationnel qui permet de gérer la sécurité de manière cohérente et alignée avec les objectifs de l'organisation. Sans gouvernance robuste, les meilleures technologies restent inefficaces : les décisions sont prises sans vision stratégique, les responsabilités sont floues, les budgets mal alloués.
Ce chapitre couvre le rôle du RSSI, les frameworks ISO 27001 et NIST CSF 2.0, les réglementations majeures (RGPD, NIS2, DORA), la gestion des incidents, et la continuité d'activité. Message clé : la conformité réglementaire n'est pas la sécurité. Elle est un plancher, pas un plafond.

OBJECTIFS PÉDAGOGIQUES
✓ Comprendre le rôle et les missions du RSSI/CISO dans l'organisation
✓ Distinguer ISO 27001:2022 et NIST CSF 2.0 et choisir le framework adapté
✓ Maîtriser les obligations RGPD, NIS2 et DORA applicables à son organisation
✓ Conduire une gestion structurée des incidents selon le NIST SP 800-61
✓ Élaborer et tester un Plan de Continuité d'Activité (PCA) et Plan de Reprise (PRA)
✓ Mettre en place une gestion du risque tiers (TPRM) pour les prestataires critiques

7.1 Gouvernance de la cybersécurité

7.1.1 Rôle et positionnement du RSSI

Le Responsable de la Sécurité des Systèmes d'Information (RSSI) — ou CISO (Chief Information Security Officer) dans la terminologie anglophone — est le dirigeant en charge de la stratégie, de la gouvernance et de l'opérationnel de la sécurité au sein de l'organisation. Son positionnement dans l'organigramme est révélateur de la maturité de l'organisation : rattaché à la DSI (risque de conflits d'intérêts), au DAF, ou directement à la Direction Générale ou au Conseil d'Administration (positionnement recommandé pour les organisations matures).

Le RSSI exerce quatre fonctions principales : la stratégie (définition de la politique de sécurité et de la roadmap, alignement avec les objectifs métier), la gouvernance (suivi du niveau de risque, reporting au COMEX/CA, coordination des parties prenantes), l'opérationnel (supervision des équipes SOC, gestion des incidents, pilotage des projets de sécurité), et la conformité (assurance du respect des réglementations applicables — RGPD, NIS2, ISO 27001, PCI-DSS selon les secteurs).

La directive NIS2 (Network and Information Security 2), transposée en droit français, renforce les exigences de gouvernance cyber en imposant la responsabilisation des organes de direction : les dirigeants doivent approuver les mesures de gestion des risques, superviser leur mise en oeuvre, et peuvent être tenus personnellement responsables des manquements. Cette évolution marque un changement de paradigme : la cybersécurité n'est plus l'affaire exclusive de la DSI, mais une responsabilité du Conseil d'Administration.

7.1.2 Politique de Sécurité des Systèmes d'Information (PSSI)

La Politique de Sécurité des Systèmes d'Information (PSSI) est le document fondateur de la gouvernance de la sécurité dans une organisation. Elle exprime les orientations stratégiques de la direction en matière de protection du SI, définit les responsabilités, pose les principes directeurs et réglemente l'usage des ressources informatiques. Elle constitue le document de référence à partir duquel déclinent toutes les politiques et procédures de sécurité opérationnelles.

Une PSSI complète couvre : la classification des informations, la politique d'accès et de contrôle d'identité, la politique de gestion des mises à jour, la politique de sauvegarde et de reprise, la politique de sécurité physique, la politique de télétravail et d'utilisation des appareils personnels (BYOD), la politique de gestion des incidents, et les sanctions en cas de non-respect. L'ANSSI publie un guide méthodologique pour l'élaboration d'une PSSI (Guide PSSI, 2004, mis à jour régulièrement).

7.2 Gestion des risques cyber

6.2.1 Méthodologie EBIOS Risk Manager

EBIOS Risk Manager (Expression des Besoins et Identification des Objectifs de Sécurité) est la méthode d'analyse et de traitement des risques de la sécurité des systèmes d'information développée par l'ANSSI (version 2018). Elle s'articule en cinq ateliers progressifs :

1. Atelier 1 — Cadrage et socle de sécurité : définition du périmètre, identification des valeurs métier, des actifs supports et des événements redoutés. Application du socle de sécurité (mesures hygiènes de base issues du référentiel de l'ANSSI).
2. Atelier 2 — Sources de risques : identification et caractérisation des sources de risques pertinentes (acteurs malveillants — état, crime organisé, concurrent, initié — et leurs objectifs) via la construction de couples « source de risque × objectif visé ».

3. Atelier 3 — Scénarios stratégiques : construction des chemins d'attaque à haut niveau entre les sources de risques et les valeurs métier ciblées, via les écosystèmes partenaires et sous-traitants (gestion du risque tiers).
4. Atelier 4 — Scénarios opérationnels : déclinaison technique des scénarios stratégiques en chemins d'attaque détaillés sur les actifs supports, avec évaluation de la vraisemblance selon les capacités des sources de risques.
5. Atelier 5 — Traitement du risque : sélection des mesures de sécurité pour traiter les risques inacceptables, évaluation du risque résiduel, élaboration du plan d'amélioration continue de la sécurité (PACS).

EBIOS RM s'inscrit dans le cadre international de l'ISO/IEC 27005 (gestion du risque en sécurité de l'information) et est compatible avec l'ISO 27001. Elle est particulièrement adaptée aux organisations françaises, aux administrations, aux OIV (Opérateurs d'Importance Vitale) et OSE (Opérateurs de Services Essentiels) soumis à la réglementation NIS/NIS2.

7.2.2 Indicateurs et tableaux de bord de sécurité

La gestion des risques cyber nécessite des indicateurs (KPI — Key Performance Indicators, KRI — Key Risk Indicators) permettant de mesurer l'efficacité du dispositif de sécurité et d'informer la direction. Les KPI opérationnels incluent : le nombre de vulnérabilités critiques non corrigées (et le délai moyen de correction — MTTD/MTTR), le taux de couverture des sauvegardes testées, le taux de conformité aux politiques (patching policy, password policy), et le nombre d'incidents de sécurité par catégorie.

Les KRI stratégiques mesurent l'exposition globale : le score de maturité cybersécurité (CMMI, C2M2), le résultat des audits et tests d'intrusion, le taux de sensibilisation des employés (résultats des campagnes de phishing simulées), et le niveau de couverture de l'assurance cyber. Le tableau de bord RSSI présente ces indicateurs à la direction de manière claire et actionnable, sans jargon technique excessif.

7.3 Cadres normatifs et réglementaires

7.3.1 ISO/IEC 27001 — Management de la sécurité de l'information

L'ISO/IEC 27001 est la norme internationale de référence pour les Systèmes de Management de la Sécurité de l'Information (SMSI). Publiée dans sa version initiale en 2005 et révisée en 2013 et 2022, elle définit les exigences pour l'établissement, la mise en oeuvre, la maintenance et l'amélioration continue d'un SMSI. Elle est certifiable par des organismes accrédités, permettant aux organisations de démontrer leur conformité à leurs clients, partenaires et régulateurs.

La structure de la norme ISO 27001:2022 suit le cadre Annexe SL (commun à toutes les normes de management ISO 9001, 14001, etc.) avec 10 chapitres : Contexte de l'organisation, Leadership, Planification, Support, Fonctionnement, Évaluation des performances, et Amélioration. L'Annexe A de la norme, désormais alignée sur ISO 27002:2022, liste 93 mesures de sécurité organisées en 4 thèmes : mesures organisationnelles (37), mesures liées aux personnes (8), mesures physiques (14), et mesures technologiques (34). La certification ISO 27001 nécessite un audit externe par un organisme certificat accrédité (COFRAC en France), précédé d'un audit interne et d'une revue de direction.

7.3.2 NIST Cybersecurity Framework (CSF)

Le NIST Cybersecurity Framework, publié en 2014 et mis à jour en version 2.0 en 2024, est le cadre de référence nord-américain pour la gestion des risques cyber. Sa popularité mondiale s'explique par sa flexibilité (applicable à toute organisation, quelle que soit sa taille ou son secteur) et sa structure intuitive. La version 2.0 étend le framework original à six fonctions : Govern (Gouverner — nouveau), Identify (Identifier), Protect (Protéger), Detect (Détecter), Respond (Répondre), Recover (Rétablir).

Chaque fonction se décline en catégories et sous-catégories (résultats de sécurité spécifiques) et en niveaux de mise en oeuvre (Implementation Tiers, de 1-Partiel à 4-Adaptatif), permettant aux organisations d'évaluer leur maturité actuelle et de définir leur profil cible. Le CSF est particulièrement utile comme langage commun entre les équipes techniques et la direction générale.

7.3.3 RGPD — Règlement Général sur la Protection des Données

Le Règlement Général sur la Protection des Données (RGPD — UE 2016/679), applicable depuis le 25 mai 2018, impose un cadre juridique contraignant pour le traitement des données personnelles des résidents européens. Ses implications en cybersécurité sont directes et significatives. Le RGPD impose la protection des données personnelles dès la conception et par défaut (Privacy by Design & by Default — Article 25), la sécurité appropriée des traitements (Article 32 — mesures techniques et organisationnelles), la notification des violations de données à l'autorité de contrôle dans un délai de 72 heures (Article 33), et la notification aux personnes concernées si le risque est élevé (Article 34).

L'analyse d'impact relative à la protection des données (AIPD — Privacy Impact Assessment) est obligatoire pour les traitements présentant un risque élevé (vidéosurveillance de grande échelle, profilage, données sensibles). Le Délégué à la Protection des Données (DPO — Data Protection Officer) est obligatoire pour certaines catégories d'organisations. Les sanctions peuvent atteindre 20 millions d'euros ou 4% du chiffre d'affaires mondial annuel pour les violations les plus graves (Méta condamné à 1,2 milliard d'euros en 2023 par la CNIL irlandaise).

7.3.4 Directive NIS2 et règlement DORA

La directive NIS2 (Network and Information Security 2 — Directive UE 2022/2555), transposée en droit national avant octobre 2024, étend considérablement le champ d'application de NIS1 : elle couvre désormais environ 10 000 entités en France (contre 300 sous NIS1), incluant des secteurs comme les services postaux, la gestion des déchets, la fabrication, les services numériques et l'administration publique. Elle distingue les entités « essentielles » (contrôle ex-ante) des entités « importantes » (contrôle ex-post). Les obligations incluent la mise en place de mesures de gestion des risques (Article 21), la notification des incidents significatifs sous 24h (alerte précoce) puis 72h (notification), et la responsabilisation des dirigeants. Les sanctions peuvent atteindre 10 millions d'euros ou 2% du CA mondial pour les entités essentielles.

Le règlement DORA (Digital Operational Resilience Act — Règlement UE 2022/2554), applicable depuis janvier 2025, vise la résilience opérationnelle numérique du secteur financier européen (banques, assurances, gestionnaires d'actifs, prestataires de services de paiement). Il impose des exigences strictes en matière de gestion des risques TIC, de tests de résilience (dont des TLPT — Threat-Led Penetration Testing), de gestion des incidents, et de gestion du risque lié aux prestataires tiers TIC (dont les fournisseurs cloud critiques).

7.3.5 Autres cadres sectoriels

CADRES RÉGLEMENTAIRES ET NORMATIFS SECTORIELS	
PCI-DSS 4.0	Payment Card Industry — Data Security Standard. Obligatoire pour les acteurs du paiement par carte. 12 exigences couvrant réseau, systèmes, données, surveillance. Version 4.0 depuis 2022 avec renforcement MFA et chiffrement.
HIPAA	Health Insurance Portability and Accountability Act (USA). Règles de sécurité pour les données de santé (ePHI). Applicable aux organisations traitant des données de patients américains.
SOC 2	Service Organization Controls — Type II. Audit de sécurité, disponibilité, intégrité, confidentialité et vie privée. Référence pour les éditeurs SaaS et prestataires cloud.
IEC 62443	Standard international pour la cybersécurité des systèmes industriels (OT/ICS/SCADA). Structure en 4 séries couvrant fondements, politiques, systèmes, composants.
HDS	Hébergeur de Données de Santé — Certification française obligatoire pour héberger des données de santé à caractère personnel. Délivrée par l'ANS (Agence du Numérique en Santé).
NIST SP 800-171	Protection des Informations non classifiées (CUI) chez les sous-traitants du gouvernement américain. Prérequis pour les contrats CMMC (Cybersecurity Maturity Model Certification — DoD).

6.6 Sécurité des tiers et gestion de la supply chain

Les attaques sur la chaîne d'approvisionnement logicielle (software supply chain attacks) sont devenues l'un des vecteurs les plus préoccupants de la cybersécurité. L'incident SolarWinds (2020) — où des attaquants russes (Cozy Bear/APT29) ont compromis le processus de build de l'éditeur SolarWinds et injecté un backdoor (SUNBURST) dans les mises à jour légitimes de l'outil Orion, affectant 18 000 organisations dont des agences gouvernementales américaines — a illustré dramatiquement ce risque. L'incident Log4Shell (CVE-2021-44228) a démontré la vulnérabilité systémique des dépendances open source.

La gestion du risque tiers (Third-Party Risk Management — TPRM) couvre l'évaluation de la sécurité des fournisseurs, sous-traitants et partenaires ayant accès aux systèmes ou données de l'organisation. Les outils de cyber risk scoring (SecurityScorecard, BitSight, RiskRecon) évaluent en continu la posture de sécurité des tiers à partir de données publiques (certificats TLS, vulnérabilités

exposées, réputation IP, Dark Web monitoring). NIS2 impose explicitement la gestion du risque tiers pour les entités essentielles et importantes.

7.2 ISO 27001 et NIST CSF 2.0

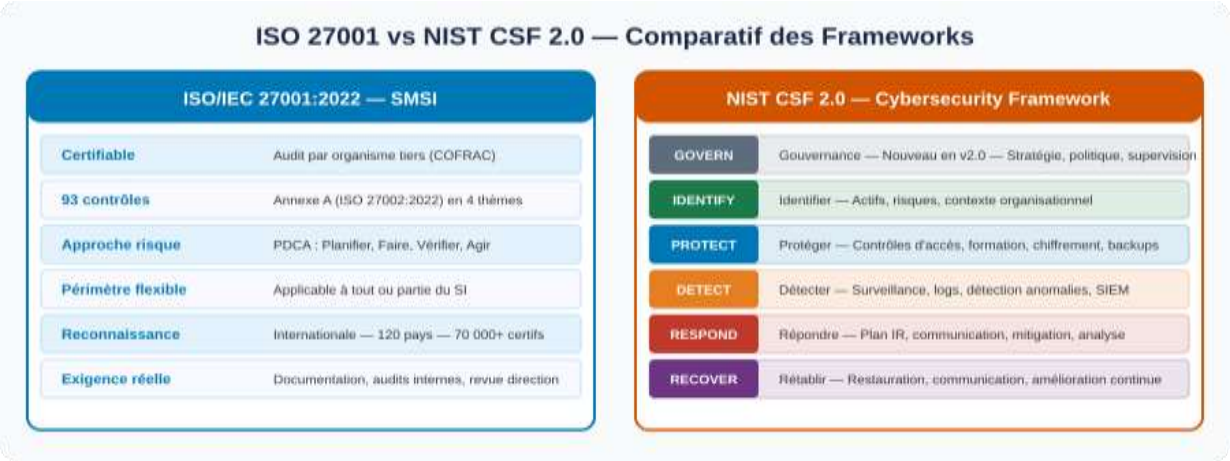

Figure 7 — ISO 27001:2022 vs NIST CSF 2.0 : Comparatif des frameworks de gouvernance

ISO 27001:2022 est la norme internationale certifiable de référence. 93 mesures en 4 thèmes. Certification tiers accrédité (COFRAC en France). NIST CSF 2.0 (2024) : 6 fonctions — Govern (nouveau), Identify, Protect, Detect, Respond, Recover. Les deux sont complémentaires : NIST CSF comme langage de communication et de priorisation, ISO 27001 comme référentiel d'implémentation et de certification.

7.3 Réglementation — RGPD, NIS2, DORA

Obligation réglementaire	Description
RGPD Art. 25	Privacy by Design & by Default — protection intégrée dès la conception.
RGPD Art. 32	Mesures techniques et organisationnelles appropriées (chiffrement, pseudonymisation, résilience).
RGPD Art. 33	Notification à la CNIL dans les 72h en cas de violation de données personnelles.
NIS2 Art. 21	Mesures de gestion des risques : sécurité des réseaux, gestion des incidents, sécurité de la chaîne d'approvisionnement.
NIS2 — Notification	Alerte précoce 24h + notification complète 72h + rapport final 1 mois.

Obligation réglementaire	Description
DORA — TLPT	Tests de résilience opérationnelle (Threat-Led Penetration Testing) obligatoires pour les entités financières critiques.

7.4 Gestion des incidents et cycle de vie

Le Plan de Continuité d'Activité (PCA / BCP — Business Continuity Plan) définit les mesures organisationnelles, techniques et humaines permettant à une organisation de maintenir ses activités critiques en cas d'incident majeur (cyberattaque, catastrophe naturelle, panne d'infrastructure). Il identifie les processus métier critiques, leurs dépendances aux systèmes IT, et les objectifs de continuité exprimés via deux indicateurs clés :

Le RTO (Recovery Time Objective) : durée maximale acceptable d'interruption d'un processus ou système. Un RTO de 4 heures signifie que le système doit être rétabli en moins de 4 heures après l'incident.

Le RPO (Recovery Point Objective) : perte de données maximale acceptable, exprimée en temps. Un RPO de 1 heure signifie que les sauvegardes doivent être effectuées toutes les heures pour limiter la perte de données à 1 heure maximum.

Le Plan de Reprise d'Activité (PRA / DRP — Disaster Recovery Plan) est le volet technique du PCA, définissant les procédures de restauration des systèmes IT critiques. La règle de sauvegarde 3-2-1 est le standard minimal : 3 copies des données, sur 2 supports différents, dont 1 hors site (et idéalement 1 hors ligne — offline — pour résister au ransomware). Les PCA/PRA doivent être testés régulièrement par des exercices de crise (tabletop exercises, test de restauration réelle) — un plan non testé est un plan non fiable.

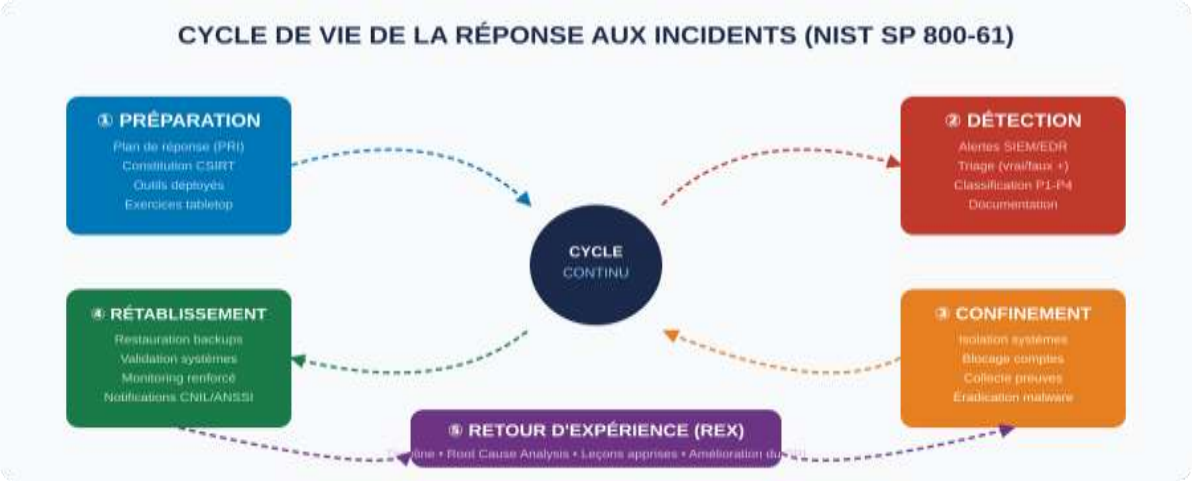

Figure 8 — Cycle de Vie de la Réponse aux Incidents (NIST SP 800-61 rev.2)

Les CERT (Computer Emergency Response Team) et CSIRT (Computer Security Incident Response Team) sont les équipes spécialisées dans la réponse aux incidents et la coordination de la cyberdéfense. À l'échelle nationale, le CERT-FR (géré par l'ANSSI) centralise la remontée des incidents affectant les administrations et les OIV, publie des alertes et bulletins de sécurité, et

coordonne la réponse aux incidents cyber majeurs affectant la nation. Europol coordonne les actions entre les CERT nationaux des États membres de l'UE à travers le réseau CSIRT européen. ENISA maintient un registre des CSIRT européens (CSIRT Network).

CHAPITRE 8 — TENDANCES ET ENJEUX ÉMERGENTS

INTRODUCTION

La cybersécurité évolue plus vite que toute autre discipline de l'informatique. Ce chapitre explore quatre domaines en mutation profonde : l'intelligence artificielle (arme à double tranchant), la convergence IT/OT et la sécurité IoT (surfaces d'attaque à impact physique), la cryptographie post-quantique (migration urgente), et la sécurité cloud et la souveraineté numérique (redistribution des responsabilités et enjeux géopolitiques).

Un professionnel qui ne suit pas ces évolutions sera rapidement dépassé. Ce chapitre pose les bases ; la veille permanente (ANSSI, ENISA, NIST, rapports IBM/Mandiant/Verizon) est la seule façon de maintenir la compétence dans un domaine aussi dynamique.

OBJECTIFS PÉDAGOGIQUES

- ✓ Analyser l'impact de l'IA générative sur les capacités offensives et défensives
- ✓ Comprendre les défis spécifiques de la sécurité IoT et de la convergence IT/OT
- ✓ Planifier la migration vers la cryptographie post-quantique (NIST 2024 FIPS 203/204/205)
- ✓ Appliquer le modèle de responsabilité partagée pour la sécurité cloud
- ✓ Comprendre les enjeux de la souveraineté numérique européenne
- ✓ Développer une démarche de veille continue en cybersécurité

8.1 Intelligence artificielle — Course aux armements algorithmique

L'intelligence artificielle transforme simultanément les capacités offensives et défensives en cybersécurité, créant une course aux armements algorithmique sans précédent. Du côté défensif, les applications de l'IA incluent : la détection d'anomalies comportementales (UEBA — User and Entity Behavior Analytics) permettant de détecter des comportements suspects même sans signature connue, l'analyse automatisée des malwares (classification par ML sans analyse manuelle), la corrélation d'alertes SIEM réduisant le volume de faux positifs, et l'automatisation des réponses aux incidents répétitifs (SOAR).

Du côté offensif, les menaces IA incluent : la génération de phishing hyper-personnalisé à grande échelle grâce aux LLM (ChatGPT, GPT-4), les deepfakes audio et vidéo utilisés pour des fraudes au CEO (virement frauduleux de 25 millions de dollars autorisé par un CFO convaincu par une fausse vidéoconférence deepfake en 2024), FraudGPT et WormGPT (LLMs non censurés vendus sur le Darknet, spécialisés dans la génération de code malveillant et de messages de phishing), et l'augmentation des capacités de fuzzing et de recherche de vulnérabilités par ML.

La gouvernance des systèmes d'IA en cybersécurité soulève des questions éthiques complexes : les décisions automatisées de blocage (par un système IPS/NDR) doivent-elles être auditables ? Comment gérer les biais dans les modèles de détection (sous-détection des attaques ciblant certains profils d'utilisateurs) ? L'EU AI Act (2024) classe les systèmes d'IA utilisés dans l'infrastructure critique comme haut risque, imposant des exigences de transparence, de robustesse et de supervision humaine.

Côté défensif : UEBA (détection d'anomalies comportementales via ML), analyse automatisée de malwares, augmentation du SOC, automatisation SOAR. Côté offensif : phishing hyper-personnalisé par LLM, deepfakes audio et vidéo (CFO dupé pour 25M$ via vidéoconférence deepfake en 2024), FraudGPT/WormGPT sur le Dark Web, automatisation de la recherche de vulnérabilités. L'EU AI Act (2024) classe les IA dans les infrastructures critiques comme haut risque.

8.2 Sécurité IoT et convergence IT/OT

L'Internet des Objets connecte des milliards d'appareils physiques — caméras de surveillance, thermostats intelligents, équipements médicaux, véhicules connectés, équipements industriels — créant une surface d'attaque gigantesque et hétérogène. Les défis spécifiques à la sécurité IoT incluent : la contrainte ressources (mémoire, CPU, énergie limitées rendant difficile l'implémentation de mécanismes cryptographiques ou de mises à jour), les cycles de vie longs (équipements industriels prévus pour 20-30 ans, impossibles à patcher régulièrement), la fragmentation (milliers de fabricants, protocoles propriétaires), et les credentials par défaut universels (Mirai a exploité massivement des caméras IP avec admin/admin).

La convergence IT/OT (Operational Technology) — l'interconnexion des réseaux informatiques traditionnels avec les systèmes de contrôle industriels (ICS — Industrial Control Systems, SCADA, PLC) — expose les infrastructures critiques (énergie, eau, transport, industrie) à des cyberattaques potentiellement à impact physique. L'attaque Industroyer/Crashoverride contre le réseau électrique ukrainien en 2016, les attaques contre une usine de traitement des eaux en Floride (2021), et les attaques récurrentes contre les hôpitaux illustrent ce risque. La norme IEC 62443 fournit le cadre de sécurité de référence pour les systèmes industriels.

Défis IoT : contraintes ressources, cycles de vie longs (20-30 ans), fragmentation extrême, credentials par défaut (Mirai 2016 — 1,1 Tbit/s via caméras IP), absence de mise à jour. Incidents OT majeurs : Industroyer/Crashoverride (Ukraine 2016), Triton/TRISIS (Arabie saoudite 2017). Norme IEC 62443 pour la sécurité des systèmes industriels. Modèle de Purdue pour la ségrégation IT/OT.

8.3 Cryptographie post-quantique — Migration urgente

L'algorithme de Shor rend RSA et ECC obsolètes sur un CRQC. Menace HNDL (Harvest Now, Decrypt Later) : collecte actuelle de données chiffrées pour déchiffrement futur. NIST 2024 : ML-KEM (FIPS 203, Kyber), ML-DSA (FIPS 204, Dilithium), SLH-DSA (FIPS 205). Plan de migration : inventaire cryptographique → priorisation → déploiement hybride → mise à jour des HSM.

8.4 Sécurité cloud

L'adoption massive du cloud computing (IaaS, PaaS, SaaS) a fondamentalement redistribué les responsabilités de sécurité selon le modèle de responsabilité partagée (Shared Responsibility Model) : le fournisseur cloud (AWS, Azure, GCP, OVH) assure la sécurité de l'infrastructure sous-jacente (hyperviseurs, réseaux physiques, datacenters), tandis que le client est responsable de la sécurité dans le cloud (configuration des services, gestion des identités, protection des données, sécurité des applications déployées).

Les principales causes de violations de données dans le cloud sont les mauvaises configurations (buckets S3 publics, groupes de sécurité trop permissifs, droits IAM excessifs) plutôt que les vulnérabilités de l'infrastructure cloud elle-même. Le CSPM (Cloud Security Posture Management) — Prisma Cloud, AWS Security Hub, Microsoft Defender for Cloud — détecte en continu les dérives de configuration. Le modèle multi-cloud (utilisation simultanée de plusieurs fournisseurs) ajoute une complexité opérationnelle et de sécurité supplémentaire.

8.5 Réglementation et souveraineté numérique

La multiplication des réglementations cyber (NIS2, DORA, RGPD, Cyber Resilience Act, AI Act en Europe ; CMMC, EO 14028 aux États-Unis) crée une pression normative croissante sur les organisations. La conformité réglementaire ne doit pas être confondue avec la sécurité effective : il est possible d'être conforme à une norme tout en restant vulnérable (compliance does not equal security), et inversement, d'avoir des pratiques de sécurité excellentes sans documentation formelle.

La souveraineté numérique — capacité d'un État ou d'une organisation à maîtriser ses données et ses technologies — est devenue un enjeu géopolitique majeur. Le CLOUD Act américain (2018) autorise les autorités américaines à accéder aux données stockées par des opérateurs américains (GAFAM) même hors des États-Unis, entrant en tension directe avec le RGPD européen. La doctrine cloud de l'État français (SecNumCloud), le projet GAIA-X européen, et les investissements dans les champions technologiques nationaux (OVHcloud, Atos) tentent de répondre à cette problématique de dépendance.

Shared Responsibility Model : le fournisseur sécurise l'infrastructure, le client sécurise la configuration, les données, les applications. Principale cause de violations cloud : mauvaises configurations. Le CLOUD Act américain (2018) crée une tension avec le RGPD européen (arrêts Schrems I/II). Réponses : SecNumCloud (ANSSI), GAIA-X, OVHcloud, Outscale.

8.5 Synthèse — Les 8 principes directeurs

Principe directeur	Description
Enjeu organisationnel	La cybersécurité est autant une question de gouvernance que de technique. La DG doit s'impliquer.
Triade CIA / DICP	Disponibilité, Intégrité, Confidentialité, Preuve : toute décision de sécurité les articule.

Principe directeur	Description
Défense en profondeur	Aucune mesure unique n'est suffisante. Superposer des couches de contrôles cohérents.
Moindre privilège	Chaque entité ne dispose que des droits strictement nécessaires. Réduire le rayon d'impact.
Assume Breach	L'attaquant est peut-être déjà présent. Investir dans la détection et la réponse.
Shift Left	La sécurité dès la conception coûte 100× moins qu'en production.
Facteur humain	L'humain est le maillon le plus vulnérable ET la première ligne de défense. Sensibilisation = meilleur ROI.
Gestion du risque	Investissements guidés par le risque réel ($R = p \times D$), pas par les modes ou la seule conformité.

CONCLUSION GÉNÉRALE

La cybersécurité est une discipline vivante, en perpétuelle évolution, dont les frontières débordent largement le domaine technique pour irriguer les questions stratégiques, économiques, juridiques, éthiques et géopolitiques. Cette version 3 du cours a introduit deux nouvelles dimensions fondamentales : la compréhension approfondie du cyberespace comme objet à protéger, et la modélisation rigoureuse de l'espace des risques comme cadre analytique central.

Le message central de cette édition : on ne peut pas sécuriser ce qu'on ne comprend pas. Comprendre le cyberespace — ses couches, ses convergences technologiques, ses systèmes d'information, ses données, ses dimensions géopolitiques — est la condition préalable à toute démarche de sécurité cohérente. Et comprendre l'espace des risques — la formule $R = p \times D$, la décomposition en cinq facteurs probabilistes, la chaîne causale de la menace aux dommages — permet de sortir de l'empirisme réactif pour construire une défense proactive et priorisée.

Le cyberespace est l'espace des possibles. Cela concerne tout le monde. On peut d'un simple clic commander une voiture, réserver un billet d'avion... Mais on peut aussi rançonner une entreprise sans bouger de sa chaise, bloquer le fonctionnement d'un hôpital avec une pièce jointe, ou désactiver à distance un processus industriel. La cybersécurité est une responsabilité collective — chaque développeur, chaque administrateur, chaque décideur, chaque utilisateur a un rôle à jouer dans la résilience numérique de nos sociétés.

Comme le rappelle Bruce Schneier : « Security is a process, not a product. » Ce cours en a posé les fondements intellectuels, conceptuels et pratiques — le reste est affaire de rigueur, de curiosité et d'engagement personnel dans une veille permanente.